

QUALIFICATIONS PACK – NATIONAL OCCUPATIONAL STANDARDS FOR IT-BPM INDUSTRY

What are National Occupational Standards(NOS)?

- NOS describe what individuals need to do, know and understand in order to carry out a particular job role or function
- NOS are performance standards that individuals must achieve when carrying out functions in the workplace, together with specifications of the underpinning knowledge and understanding

Contact Us:

IT-ITes SSC NASSCOM

E-mail:

ssc@nasscom.in



Contents

1. Introduction and Contacts..... P.1
2. Qualifications Pack P.2
3. Glossary of Key Terms P.3
4. NOS Units..... P.5
5. Nomenclature for QP and NOS Units P.61
6. Criteria for Assessment of Trainees..... P.63

Introduction

Qualifications Pack- Analyst Application Security

SECTOR: IT-ITes

SUB-SECTOR: IT Services

OCCUPATION: Information/Cyber Security

REFERENCE ID: SSC/Q0903

ALIGNED TO: NCO-2015/ NIL

Analyst Application Security in the IT-ITes Industry is also known as Engineer Application Security. In consulting firms the role is known as Consultant Application Security.

Brief Job Description: Individuals at this job are responsible for vulnerability assessment for applications, performing source code review, testing the source code, suggesting remediation actions, perform hardening and monitor organization's traffic and logs for threats.

Personal Attributes: This job may require the individual to work independently and take decisions for his/her own area of work. The individual should be result oriented and have a high attention for detail. The individual should also be able to demonstrate communication skills, logical thinking along with willingness to undertake desk-based job with long hours.



Job Details	Qualifications Pack Code	SSC/Q0903		
	Job Role	Analyst Application Security This job role is applicable in both national and international scenarios		
	Credits (NSQF)	TBD	Version number	1.0
	Sector	IT-ITes	Drafted on	18/08/2016
	Sub-sector	IT Services	Last reviewed on	31/03/2018
	Occupation	Information/Cyber Security	Next review date	31/03/2019
	NSQC Clearance on	19/12/2018		

Job Role	Analyst Application Security (Engineer – Application Security)
Role Description	Responsible for analysing application deployment architecture, security controls & taking corrective actions
NSQF level	7
Minimum Educational Qualifications	Diploma in Engineering(with 1 year experience) or Bachelor's Degree in Science/Technology/Computers
Maximum Educational Qualifications	Not Applicable
Training (Suggested but not mandatory)	Certification in Information systems or related fields, Programming languages, coding, Basic soft skills training, ethical hacking or pertaining to ISO27001
Minimum Job Entry Age	21 years
Experience	0-2 years of work experience/internship in security
Applicable National Occupational Standards (NOS)	Compulsory: 1. SSC/N0909 Identify and analyze exposures and weaknesses in applications and their deployments 2. SSC/N0910 Harden application and deployment configurations for minimizing exposure and vulnerabilities 3. SSC/N0911 Monitor applications and solutions deployed for possible breaches and compromises 4. SSC/N9001 Manage your work to meet requirements 5. SSC/N9002 Work effectively with colleagues 6. SSC/N9003 Maintain a healthy, safe and secure working environment 7. SSC/N9004 Provide data/information in standard formats 8. SSC/N9005 Develop your knowledge, skills and competence Optional: Not Applicable
Performance Criteria	As described in the relevant NOS units

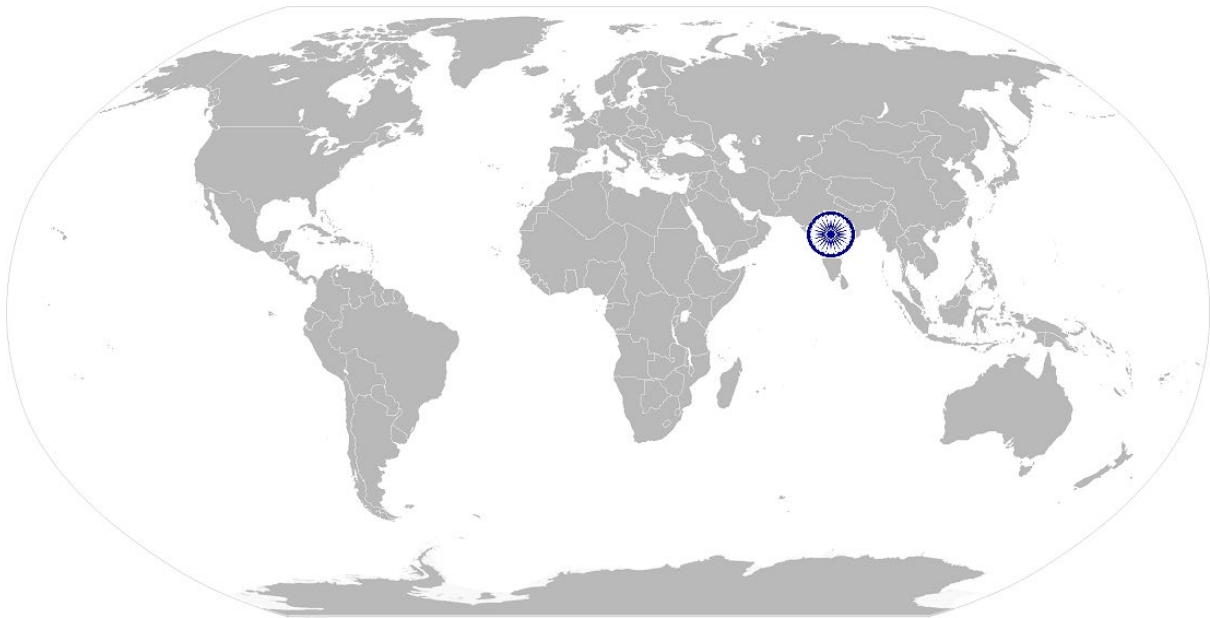
Glossary of Key Terms

Definitions	Keywords /Terms	Description
	Sector	Sector is a conglomeration of different business operations having similar businesses and interests. It may also be defined as a distinct subset of the economy whose components share similar characteristics and interests.
	Sub-sector	Sub-sector is derived from a further breakdown based on the characteristics and interests of its components.
	Vertical	Vertical may exist within a sub-sector representing different domain areas or the client industries served by the industry.
	Occupation	Occupation is a set of job roles, which perform similar/related set of functions in an industry.
	Function	Function is an activity necessary for achieving the key purpose of the sector, occupation, or area of work, which can be carried out by a person or a group of persons. Functions are identified through functional analysis and form the basis of OS.
	Sub-functions	Sub-functions are sub-activities essential to fulfill the achieving the objectives of the function.
	Job role	Job role defines a unique set of functions that together form a unique employment opportunity in an organization.
	Occupational Standards (OS)	OS specify the standards of performance an individual must achieve when carrying out a function in the workplace, together with the knowledge and understanding they need to meet that standard consistently. Occupational Standards are applicable both in the Indian and global contexts.
	Performance Criteria	Performance Criteria are statements that together specify the standard of performance required when carrying out a task.
	National Occupational Standards (NOS)	NOS are Occupational Standards which apply uniquely in the Indian context.
	Qualifications Pack Code	Qualifications Pack Code is a unique reference code that identifies a qualifications pack.
	Qualifications Pack(QP)	Qualifications Pack comprises the set of OS, together with the educational, training and other criteria required to perform a job role. A Qualifications Pack is assigned a unique qualification pack code.
	Unit Code	Unit Code is a unique identifier for an OS unit, which can be denoted with either an 'O' or an 'N'.
	Unit Title	Unit Title gives a clear overall statement about what the incumbent should be able to do.
	Description	Description gives a short summary of the unit content. This would be helpful to anyone searching on a database to verify that this is the appropriate OS they are looking for.
	Scope	Scope is the set of statements specifying the range of variables that an individual may have to deal with in carrying out the function which have a critical impact on the quality of performance required.

Knowledge and Understanding	Knowledge and Understanding are statements which together specify the technical, generic, professional and organizational specific knowledge that an individual needs in order to perform to the required standard.
Organizational Context	Organizational Context includes the way the organization is structured and how it operates, including the extent of operative knowledge managers have of their relevant areas of responsibility.
Technical Knowledge	Technical Knowledge is the specific knowledge needed to accomplish specific designated responsibilities.
Core Skills/Generic Skills	Core Skills or Generic Skills are a group of skills that are key to learning and working in today's world. These skills are typically needed in any work environment. In the context of the OS, these include communication related skills that are applicable to most job roles.
Helpdesk	Helpdesk is an entity to which the customers will report their IT problems. IT Service Helpdesk Attendant is responsible for managing the helpdesk.
Keywords /Terms	Description
IT-ITes	Information Technology - Information Technology enabled Services
BPM	Business Process Management
BPO	Business Process Outsourcing
KPO	Knowledge Process Outsourcing
LPO	Legal Process Outsourcing
IPO	Information Process Outsourcing
BCA	Bachelor of Computer Applications
B.Sc.	Bachelor of Science
OS	Occupational Standard(s)
NOS	National Occupational Standard(s)
QP	Qualifications Pack
UGC	University Grants Commission
MHRD	Ministry of Human Resource Development
MoLE	Ministry of Labour and Employment
NVEQF	National Vocational Education Qualifications Framework
NVQF	National Vocational Qualifications Framework
NSQF	National Skill Qualification Framework

Acronyms

National Occupational Standard



Overview

This unit is about performing application vulnerability assessment.

SSC/N0909

Identify and analyse exposures and weaknesses in applications and their deployments

Applicable NOS Unit

Unit Code	SSC/N0909
Unit Title (Task)	Identify and analyze exposures and weaknesses in applications and their deployments
Description	This unit is about performing application vulnerability assessment.
Scope	This unit/task covers the following: Preliminary Information is: e.g. • scope and schedule of work • type of assessment • business priorities • type of application • Application Architecture • LLD (Low Level Design) and HLD (High Level Design) of Application • constraints • already identified risks and vulnerabilities • possible areas of weakness, etc. Various factors for evaluating criticality of information are: e.g. • business importance of the application • role of lines of business and other supporting functions in determining the criticality of the application • client requirements • security risk exposure • compliance requirement (Sector, Geography of the information and applicable legislation) • commercial and economic implications, etc. Various factors to evaluate application category are: • type of application - such as legacy applications, custom code, third party application, mobile application, communication & integration APIs and packaged enterprise applications like ERP & CRM • type of environment -Development, Test, staging, production, etc. • externally provisioned systems - third party or client systems • application programming interfaces Automated tools and techniques for gathering web-based information are: • search engine discovery and for information leakage

Identify and analyse exposures and weaknesses in applications and their deployments

- web crawlers
- identify application entry points
- map execution paths such as data flow through application

Various sources of threats are: e.g.

- internal and external factors
- vulnerabilities at code, platform and infrastructure level
- deployment gaps and configuration errors
- integration issues
- transactional issues
- exposure of sensitive data
- gaps in access mechanism
- runtime errors
- automated scripts issue
- unsecured APIs, etc.

Internal sources for collating application information security controls are: e.g.

- historical vulnerability trend of application
- vulnerability scans
- penetration testing results
- Documented SDLC and secure Code Review
- web application firewalls and intrusion prevention systems
- Segregation of Duties (SoD) Controls
- web access management

External sources for collating application information security controls are: e.g.

- vulnerability databases
- exploit& threat databases
- vendor alerts
- third party penetration testers
- Security Incident and Event Management (SIEM) Solutions

Various sources for collating information about the application are: e.g.

- subscription to feeds
- reviewing analyst reports
- reviewing security blogs
- product / application platforms or its API white papers, etc.

Identify and analyse exposures and weaknesses in applications and their deployments

Relevant information to be captured in the documentation tracker includes:

- risk exposure
- any application deficiency identified in the past
- nature of issues or vulnerabilities or exploits
- compiling references
- root cause analysis
- corrective actions
- case studies of peers

Various parameters to be included in the plan for penetration testing are:

- testing methodology
- complexity (basic, focused, comprehensive, etc.)
- testing type (black box or white box)
- high level calendar of events
- security incident handling protocol during testing
- communication requirements in advance and during testing
- authorization requirements prior to performing tests
- removal of tools and data after testing
- permitted transmission of assessment data through trusted and untrusted environments
- safeguarding of test results
- confidentiality of disclosure
- distribution of findings

Various testing methods for testing applications are:

- configuration and deployment management testing
- enumerate all the roles that can be provisioned and explore the permissions that are allowed to be applied to the objects including any constraints
- identity management testing
- authentication testing
- authorization testing
- session management testing
- input validation testing
- business logic testing
- client side testing

Identify and analyse exposures and weaknesses in applications and their deployments

Operating procedures include:

- required service levels (e.g. availability, quality)
- routine maintenance
- monitoring
- data integrity (e.g. backups, anti-virus)
- consumables use, storage & disposal
- health & safety
- escalation
- information recording and reporting
- obtaining work permissions
- security & confidentiality

Basic Cyber Security concepts are: e.g.

- the importance of confidentiality, integrity and availability for information systems
- common types of malicious code- a. virus, b. Trojan; c. logic bomb, d. worm, e. spyware, f. Malwares, g. spoofing, h. phishing, i. Ddos attacks
- types of threats facing the information security of individuals and organisations
- sources of threats to information security in terms of opportunity, ability and motive, etc.

Relevant networking concepts, devices and terminology such as:

- Concepts: OSI (Open Systems Interconnection) Model/topology; Network Protocols, bandwidth management, Vlan, Access control list, Active directory services, port mapping etc.
- Devices: switches, routers, servers, transmission media, Intrusion Protection System (IPS), Load balancers, Firewall etc.
- Terminology: Secure Sockets Layer (SSL), Virtual Private Network (VPN), Two Factor Authentication (2FA), Encryption, Cryptography, smart cards, biometrics, Single sign-on (SSO), Active Directory, Lightweight Directory Access Protocol (LDAP) etc.

Public databases and vulnerability sharing clubs are: e.g.

- Bugtraq
- the National Institute of Standards and Technology (NIST) NVB
- the United States Computer Emergency Readiness Team (US-CERT)
- the Open Source Vulnerability Database (OSVDB), etc.

Identify and analyse exposures and weaknesses in applications and their deployments

Performance Criteria (PC) w.r.t. the Scope

To be competent, you must be able to:

- PC1. gather **preliminary information** about the application through manual documentation review
- PC2. evaluate the criticality of information by taking into consideration **various factors**
- PC3. identify the application type/category by considering **various factors**
- PC4. gather web-based information through the use of **automated tools and techniques**
- PC5. establish the application functionality, connectivity, interdependency and working
- PC6. review application design and architecture to check that appropriate security requirements are enforced
- PC7. check the source code of an application manually and identify security issues
- PC8. explore potential threats by considering threats from **various sources**
- PC9. evaluate the vulnerabilities discovered for their relevance, root causes, risk criticality, and corresponding mitigation methods
- PC10. collate application security controls from **various internal and external sources**
- PC11. collate information about the application with respect to industry trends through **various sources**
- PC12. gather information related to application patching and its interdependencies with IT infrastructure requirements
- PC13. assess application vulnerability using security assessment tools
- PC14. isolate root causes of vulnerabilities and identify fixes, by including contextual information like architectural composition, exploitation methods, and probabilities of exposure
- PC15. validate data to identify failed false positives and individual vulnerabilities
- PC16. categorize vulnerabilities and identify extent of vulnerability including level of weakness and sensitivity of the information
- PC17. develop an application tracker capturing **relevant information**
- PC18. plan for application penetration testing covering **various parameters**
- PC19. test applications using **various testing methods**
- PC20. conduct penetration testing using automatic scanning technologies, "black box testing, as well as manual tests that use human intelligence to guide the steps
- PC21. capture the requirements for securing applications stipulated by clients & external stakeholders in designated format during the application life cycle

Identify and analyse exposures and weaknesses in applications and their deployments

	PC22. document information and activities at every step to provide an audit trail PC23. secure storage of data collected during the assessment, including vulnerabilities, analysis results, and mitigation recommendations PC24. automate correlation of static, dynamic and interactive application security testing results
Knowledge and Understanding (K)	
A. Organizational Context (Knowledge of the company/ organization and its processes)	You need to know and understand: KA1. relevant legislation, standards, policies, and procedures followed in the company KA2. organization's knowledge base and how to access and update this KA3. limits of your role and responsibilities and who to seek guidance from KA4. the organizational systems, procedures and tasks/checklists within the domain and how to use these KA5. the operating procedures that are applicable to the system(s) being used, typical response times and service times related to own work area KA6. standard tools and templates available and how to use these
B. Technical Knowledge	You need to know and understand: KB1. basic cyber security concepts KB2. relevant networking concepts, devices and terminologies KB3. secure Software Development Lifecycle (SDLC) KB4. what are applications, types of applications and common application security requirements KB5. the basic functionalities of the applications and role based access that are used by the customers KB6. how software vulnerabilities can be identified and resolved for applications KB7. application / database layer intrusion detection / prevention appliance KB8. OWASP tools and methodologies KB9. common Vulnerability and Exposures (CVE) language, which standardizes descriptions of vulnerabilities KB10. code scanning toolsets KB11. security assessment tools KB12. new technological developments in application security KB13. basics of mobile application security and cloud application security KB14. key features of mobile application and cloud application security testing tools KB15. systems engineering theories, concepts, and methods Systems/Product Life Cycle KB16. scripting knowledge (Shell Script, Java Script) KB17. basics of encryption algorithms

Identify and analyse exposures and weaknesses in applications and their deployments

	KB18. common security requirements within web (thin client) and desktop (thick client) applications KB19. security solutions like web application Firewall, IDS/IPS, web security gateways, email security, content Filtering, etc. KB20. tools that focus on application penetration testing KB21. access to public databases and vulnerability sharing clubs
Skills (S)	
A. Core Skills/ Generic Skills	Writing Skills
	You need to know and understand how to: SA1. complete accurate well written work with attention to detail SA2. document call logs, reports, task lists, and schedules with co-workers SA3. prepare status and progress reports SA4. write memos and e-mail to customers, co-workers, and vendors to provide them with work updates and to request appropriate information without English language errors regarding grammar or sentence construct and following professional etiquettes
	Reading Skills
	You need to know and understand how to: SA5. read about new products and services with reference to the organization and also from external forums such as websites and blogs SA6. keep abreast with the latest knowledge by reading brochures, pamphlets, and product information sheets SA7. read comments, suggestions, and responses to Frequently Asked Questions (FAQs) posted on the helpdesk portal SA8. read policy manual, standard operating procedures and service level agreements relevant to work area SA9. read emails received from own team, across team and external vendors and clients
B. Professional Skills	Oral Communication (Listening and Speaking skills)
	You need to know and understand how to: SA10. discuss task lists, schedules, and work-loads with co-workers SA11. give clear instructions to specialists/vendors/users/clients as required SA12. keep stakeholders informed about progress SA13. avoid using jargon, slang or acronyms when communicating with a customer, unless it is required SA14. receive and make phone calls, including call forward, call hold, and call mute
B. Professional Skills	Decision Making
	You need to know and understand how to:

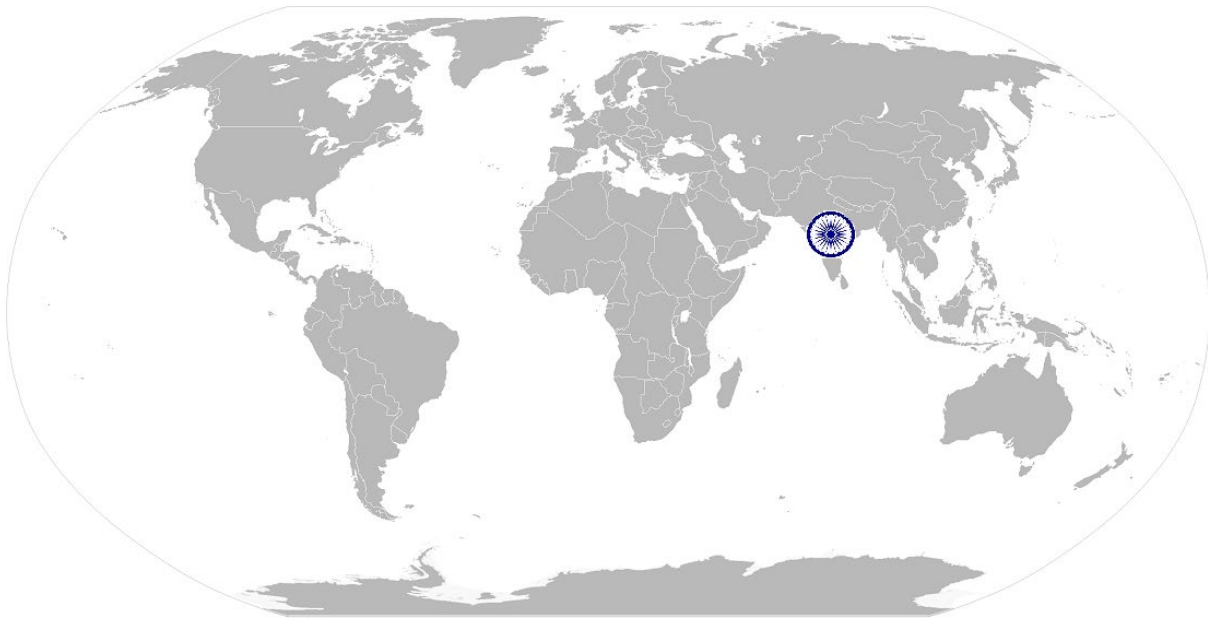
Identify and analyse exposures and weaknesses in applications and their deployments

	SB1. follow rule-based decision-making processes
	SB2. make a decision on a suitable course of action
	Plan and Organize
	You need to know and understand how to:
	SB3. plan and organize your work to achieve targets and deadlines
	Customer Centricity
	You need to know and understand how to:
	SB4. Identify internal or external customer requirement and priorities clearly with respect to work at hand
	SB5. carry out rule-based transactions in line with customer-specific guidelines, procedures, rules and service level agreements
	SB6. check that your own and/or your peers work meets customer requirements
	Problem Solving
	You need to know and understand how to:
	SB7. apply problem-solving approaches in different situations
	SB8. seek clarification on problems from others
	Analytical Thinking
	You need to know and understand how to:
	SB9. analyze data and activities
	SB10. configure data and disseminate relevant information to others
	SB11. pass on relevant information to others
	Critical Thinking
	You need to know and understand how to:
	SB12. provide opinions on work in a detailed and constructive way
	SB13. apply balanced judgments to different situations
	Attention to Detail
	You need to know and understand how to:
	SB14. check your work is complete and free from errors
	Team Working
	You need to know and understand how to:
	SB15. work effectively in a team environment
	SB16. work independently and collaboratively
C. Technical Skills	You need to know and understand how to:
	SC1. perform writing and testing of web applications/ web services in various programming languages such as C/C++, Java, and JavaScript programming
	SC2. read and write coded scripts and modify and debug programs
	SC3. work on various operating system

SSC/N0909

Identify and analyse exposures and weaknesses in applications and their deployments

	SC4. work with word processors, spreadsheets and presentations SC5. stay abreast of the latest developments in terms of industry standards and information security tools and techniques
--	--

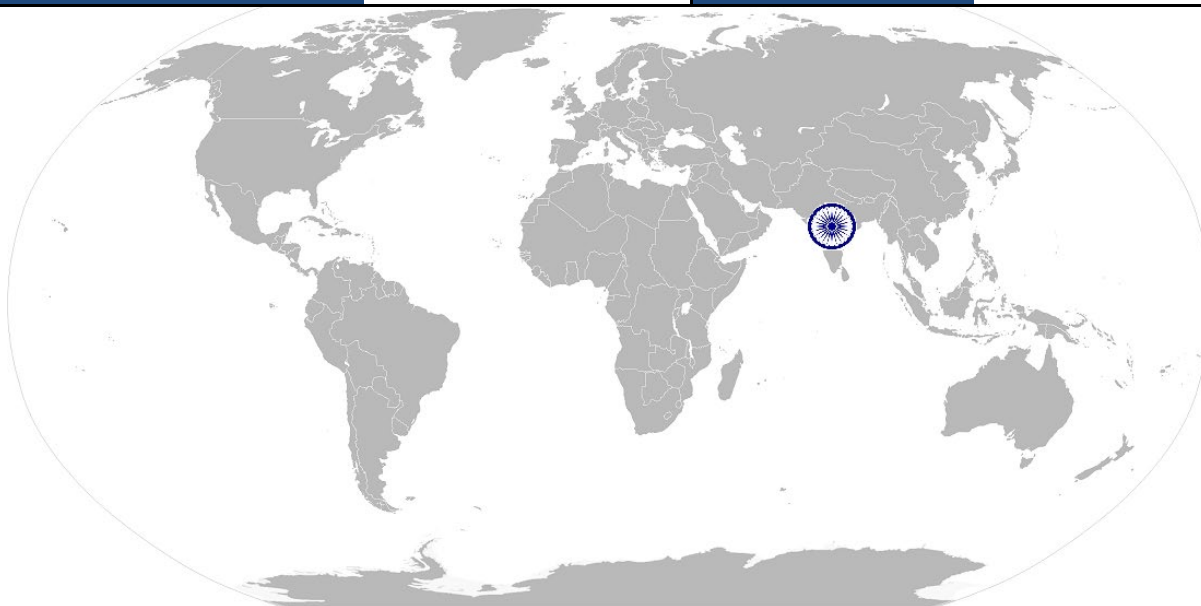


SSC/N0909

Identify and analyse exposures and weaknesses in applications and their deployments

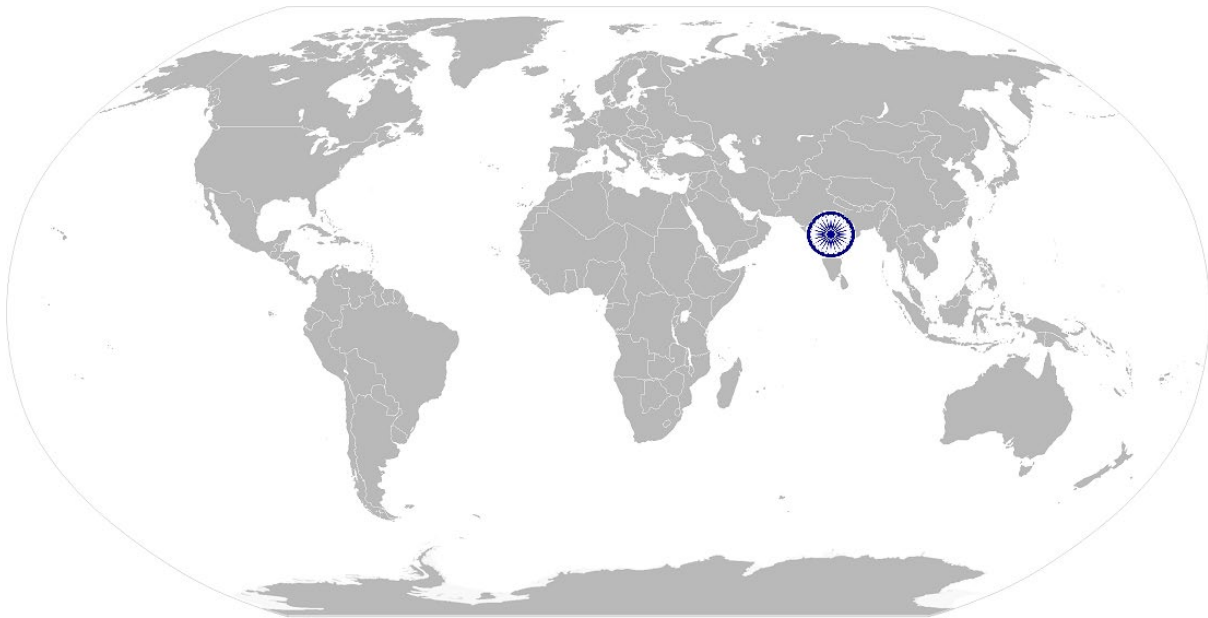
NOS Version Control

NOS Code	SSC/N0909		
Credits (NSQF)	TBD	Version number	1.0
Industry	IT-ITeS	Drafted on	18/08/2016
Industry Sub-sector	IT Services	Last reviewed on	31/03/2018
Occupation	Information/Cyber Security	Next review date	31/03/2019



Harden application and deployment configurations for minimizing exposure and vulnerabilities

National Occupational Standard



Overview

This unit is about performing hardening activities such as secure configurations, removing unauthorized applications and updating authorized patches, etc. in order to minimize exposure and vulnerabilities.

SSC/N0910

Harden application and deployment configurations for minimizing exposure and vulnerabilities

Applicable NOS Unit	Unit Code	SSC/N0910
	Unit Title (Task)	Harden application and deployment configurations for minimizing exposure and vulnerabilities
	Description	This unit is about performing hardening activities such as secure configurations, removing unauthorized applications and updating authorized patches, etc. in order to minimize exposure and vulnerabilities.
	Scope	This unit/task covers the following: Various relevant factors considered while defining strategy for management of patches and updates are: • diverse IT infrastructure components and their specific requirements • availability of patching solutions and their deployment requirements • process requirements for patch management • environments that may require testing of new patch releases • release and update strategy • capacity requirements for management of patch and updates Various parameters considered while identifying a patch management life cycle process are: e.g. • change assessment • change scheduling • QA testing • packaging and engineering • distribution • installation • verification, • etc. IT infrastructure processes that are to be reengineered as per the patch management requirements: • asset management • capacity management • change management • configuration management • problem management • service management

Harden application and deployment configurations for minimizing exposure and vulnerabilities

Operating procedures include:

- required service levels (e.g. availability, quality)
- routine maintenance
- monitoring
- data integrity (e.g. backups, anti-virus)
- consumables use, storage & disposal
- health & safety
- escalation
- information recording and reporting
- obtaining work permissions
- security & confidentiality

Basic Cyber Security concepts are: e.g.

- the importance of confidentiality, integrity and availability for information systems
- common types of malicious code- a. virus, b. Trojan; c. logic bomb, d. worm, e. spyware, f. Malwares, g. spoofing, h. phishing, i. Ddos attacks
- types of threats facing the information security of individuals and organisations
- sources of threats to information security in terms of opportunity, ability and motive, etc.

Relevant networking concepts, devices and terminology such as:

- Concepts: OSI (Open Systems Interconnection) Model/topology; Network Protocols, bandwidth management, Vlan, Access control list, Active directory services, port mapping etc.
- Devices: switches, routers, servers, transmission media, Intrusion Protection System(IPS), Load balancers, Firewall etc.
- Terminology: Secure Sockets Layer (SSL), Virtual Private Network (VPN), Two Factor Authentication (2FA), Encryption, Cryptography, smart cards, biometrics, Single sign-on (SSO), Active Directory, Lightweight Directory Access Protocol (LDAP) etc.

Scripting knowledge

- Shell Script
- Java Script

Security solutions:

Harden application and deployment configurations for minimizing exposure and vulnerabilities

	• Firewall • IDS/IPS • web security gateways • email security • content management
Performance Criteria (PC) w.r.t. the Scope	
	To be competent, you must be able to: PC1. identify all web servers and web applications on the network and secure their administrative consoles PC2. review the list of all applications and ensure valid credentials are required to connect PC3. review list of systems and applications to identify and uninstall unauthorized instances and extraneous functionality to reduce the chance of exploitation PC4. apply access controls to applications and databases as required as per policy PC5. ensure all web servers, web applications and databases are patched as per latest guidelines PC6. ensure all follow security technical implementation guides (STIGs) to ensure compliance with best practices PC7. review logs for web attacks and identify signs of compromise PC8. implement application and database defences such as firewalls, load balancer PC9. ensure that all applications connect with least privilege PC10. limit and monitor file creation in all web accessible directories PC11. configure application securely across the environments for minimum exposure and weaknesses PC12. secure applications using tools and solutions such as application testing, code review, web application firewall, etc. PC13. check frontend and backend platforms for reported vulnerabilities and available patches or updates PC14. work on the established guidelines (or establish new ones with the support of a senior) for security configuration and hardening for each category of applications PC15. establish mechanism and measures to ensure that security, antivirus updates and patches are effectively applied on all the application assets PC16. define security baseline for malware protection — at servers, endpoints and applications and their signatures updates including patch/security updates PC17. make the business users aware about application vulnerability and patch requirements

Harden application and deployment configurations for minimizing exposure and vulnerabilities

	PC18. define strategy for management of patches and updates considering various relevant factors PC19. identify a patch management life cycle process considering various parameters PC20. integrate patch management with the operational cycle of IT infrastructure management PC21. ensure that IT infrastructure processes are reengineered as per the patch management requirements PC22. research best practices in hardening applications PC23. document results of the outcome of the tools and solutions used
Knowledge and Understanding (K)	
A. Organizational Context (Knowledge of the company/ organization and its processes)	You need to know and understand: KA1. relevant legislation, standards, policies, and procedures followed in the company KA2. organization's knowledge base and how to access and update this KA3. limits of your role and responsibilities and who to seek guidance from KA4. the organizational systems, procedures and tasks/checklists within the domain and how to use these KA5. the operating procedures that are applicable to the system(s) being used, typical response times and service times related to own work area
B. Technical Knowledge	You need to know and understand: KB1. basic cyber security concepts KB2. relevant networking concepts, devices and terminologies KB3. standard Systems Development Lifecycle (SDLC) practices and process KB4. the enterprise information technology (IT) architecture Information Technology Architecture KB5. what are applications, types of applications and common application security requirements KB6. the basic functionalities of the applications, hardware and/or access rights that are used by the customers KB7. how hardware and software vulnerabilities can be identified and resolved for applications KB8. application / database layer intrusion detection / prevention appliance KB9. measures or indicators of system performance and availability Information KB10. new technological developments in application security KB11. basics of mobile application security and cloud application security KB12. server administration and systems engineering theories, concepts, and methods Systems/Product Life Cycle KB13. scripting knowledge (Shell Script, Java Script)

Harden application and deployment configurations for minimizing exposure and vulnerabilities

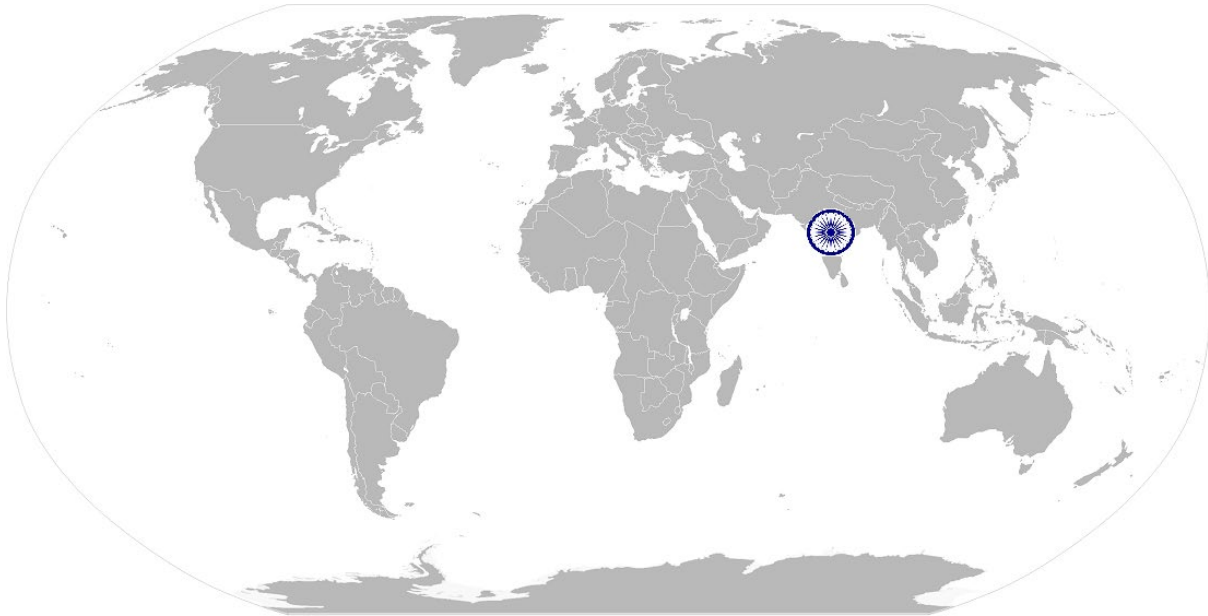
	KB14. knowledge-base of the known problems KB15. security solutions like Firewall, IDS/IPS, web security gateways, email security, content management, etc. KB16. common Vulnerability and Exposures (CVE) language, which standardizes descriptions of vulnerabilities KB17. Secure configuration of applications KB18. Application Hardening processes and best practices KB19. Patch management
Skills (S)	
A. Core Skills/ Generic Skills	Writing Skills
	The user/ individual on the job needs to know and understand how to: SA1. document call logs, reports, task lists, and schedules with co-workers SA2. prepare status and progress reports SA3. write memos and e-mail to customers, co-workers, and vendors to provide them with work updates and to request appropriate information without English language errors regarding grammar or sentence construct and following professional etiquettes
	Reading Skills
	The user/individual on the job needs to know and understand how to: SA4. read about new products and services with reference to the organization and also from external forums such as websites and blogs SA5. keep abreast with the latest knowledge by reading brochures, pamphlets, and product information sheets SA6. read comments, suggestions, and responses to Frequently Asked Questions (FAQs) posted on the helpdesk portal SA7. read policy manual, standard operating procedures and service level agreements relevant to work area SA8. read emails received from own team, across team and external vendors and clients
	Oral Communication (Listening and Speaking skills)
	The user/individual on the job needs to know and understand how to: SA9. discuss task lists, schedules, and work-loads with co-workers SA10. give clear instructions to specialists/vendors/users/clients as required SA11. keep stakeholders informed about progress SA12. avoid using jargon, slang or acronyms when communicating with a customer, unless it is required SA13. receive and make phone calls, including call forward, call hold, and call mute
B. Professional Skills	Decision Making

Harden application and deployment configurations for minimizing exposure and vulnerabilities

	The user/individual on the job needs to know and understand how to:
	SB1. follow rule-based decision-making processes
	SB2. make decisions on suitable courses of action
	Plan and Organize
	The user/individual on the job needs to know and understand:
	SB3. plan and organize your work to achieve targets and deadlines
	Customer Centricity
	The user/individual on the job needs to know and understand how to:
	SB4. carry out rule-based transactions in line with customer-specific guidelines, procedures, rules and service level agreements
	SB5. check your own and/or your peers work meets customer requirements
	Problem Solving
	The user/individual on the job needs to know and understand how to:
	SB6. apply problem-solving approaches in different situations
	SB7. seek clarification on problems from others
	Analytical Thinking
	The user/individual on the job needs to know and understand how to:
	SB8. analyze data and activities
	SB9. configure data and disseminate relevant information to others
	SB10. pass on relevant information to others
	Critical Thinking
	The user/individual on the job needs to know and understand how to:
	SB11. provide opinions on work in a detailed and constructive way
	SB12. apply balanced judgments to different situations
	Attention to Detail
	You need to know and understand how to:
	SB13. apply good attention to details
	SB14. check your work is complete and free from errors
	Team Working
	You need to know and understand how to:
	SB15. work effectively in a team environment
	SB16. contribute to the quality of team working
	SB17. work independently and collaboratively
C. Technical Skills	You need to know and understand how to:
	SC1. perform writing and testing of web applications/ web services in various programming languages such as C/C++, Java, and JavaScript programming;
	SC2. do HTTP and web programming

Harden application and deployment configurations for minimizing exposure and vulnerabilities

	SC3. read and write coded scripts and modify and debug programs SC4. work on various operating systems SC5. work with word processors, spreadsheets and presentations SC6. perform basic application penetration testing and ethical hacking SC7. stay abreast of the latest developments in terms of industry standards and information security tools and techniques
--	---

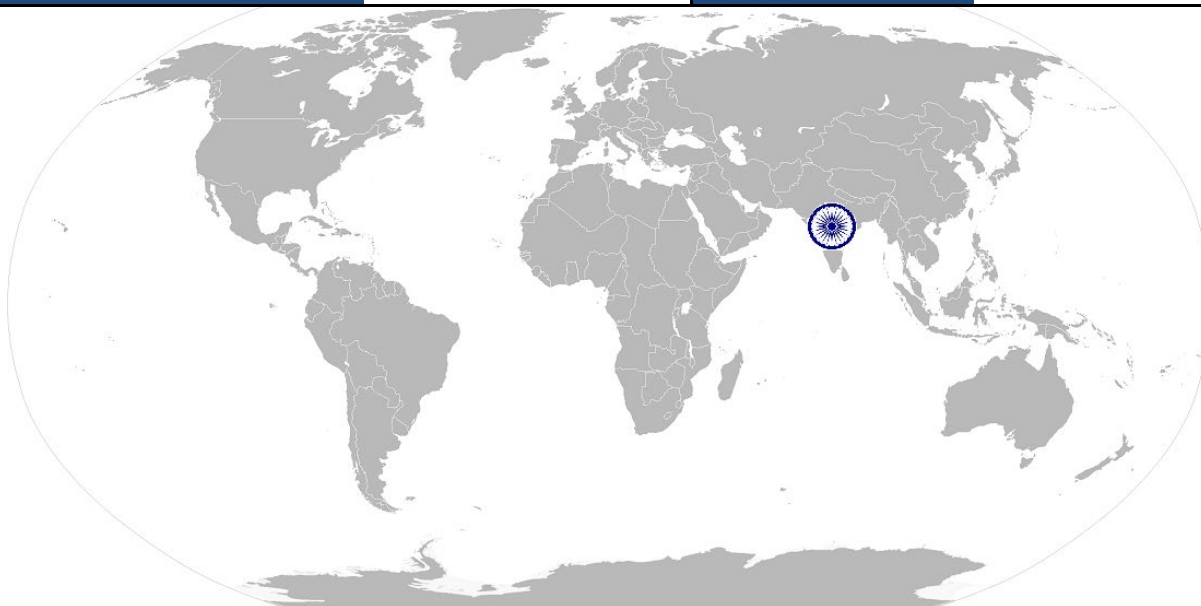


SSC/N0910

Harden application and deployment configurations for minimizing exposure and vulnerabilities

NOS Version Control

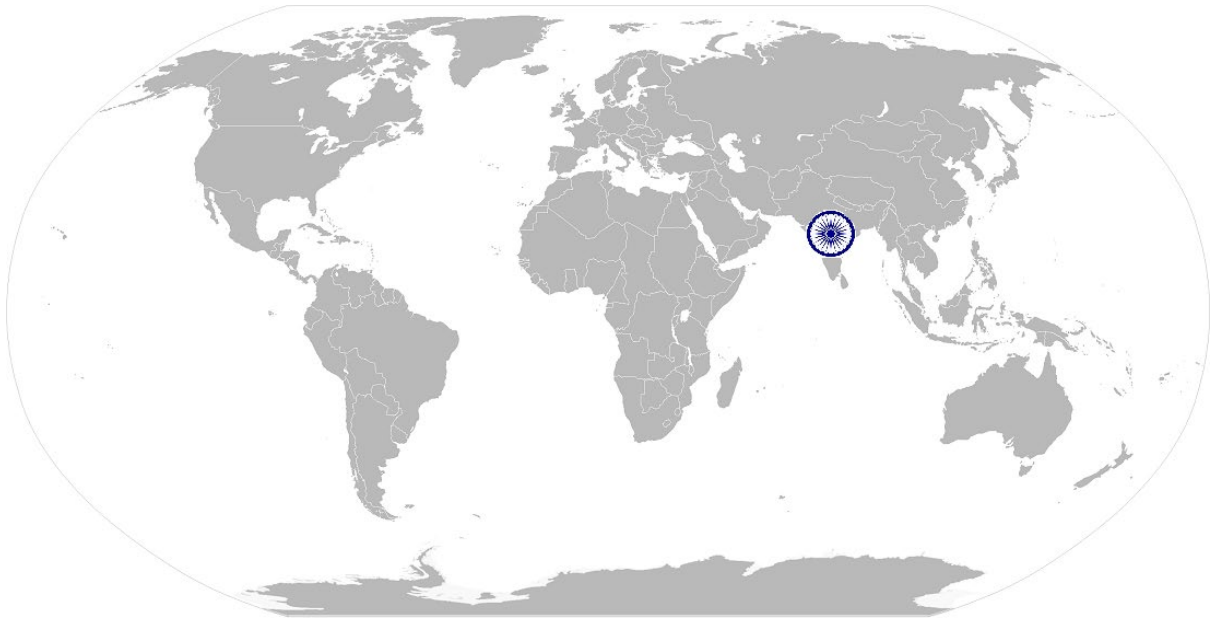
NOS Code	SSC/N0910		
Credits (NSQF)	TBD	Version number	1.0
Industry	IT-ITeS	Drafted on	18/08/2016
Industry Sub-sector	IT Services	Last reviewed on	31/03/2018
Occupation	Information/Cyber Security	Next review date	31/03/2019



SSC/N0911

Monitor applications and solutions deployed for their security for possible breaches and compromises

National Occupational Standard



Overview

This unit is about monitoring the events in application consoles and raising incidents based on the 1st level analysis and following up to ensure response within agreed timelines.

SSC/N0911

Monitor applications and solutions deployed for their security for possible breaches and compromises

Applicable NOS Unit

Unit Code	SSC/N0911
Unit Title (Task)	Monitor applications and solutions deployed for their security for possible breaches and compromises
Description	This unit is about monitoring the events in application consoles and raising incidents based on the 1st level analysis and following up to ensure response within agreed timelines.
Scope	This unit/task covers the following: Tools and infrastructure are: • infrastructure management services like antivirus management, firewall management/ reviews, device configurations, etc. • tools which manage end point security services • transactional monitoring and analysis • tools which monitor spams, virus, malware • tools related to phishing, URL monitoring, email filtering • architecture for log collection and management Operational processes are: e.g. • configuration of log sources • collection of logs and frequency of collection • storage of log data • management and review of logs, etc. Key events and activity logs are: e.g. • individual user accesses • rejected systems, applications, file and data accesses • attempts and other failed actions • privileged, administrative or root accesses • use of identification and authentication mechanisms • remote and wireless accesses • changes to system or application configurations • changes to access rights • use of system utilities • activation or deactivation of security systems • accesses to audit logs, etc. Events and activity logs are: e.g. • activity or event type (e.g. login attempt, file access, etc.)

SSC/N0911

Monitor applications and solutions deployed for their security for possible breaches and compromises

- user identification
- session ID and/or terminal ID
- network addresses
- date and time
- success or failure indication, etc.

Incident/breach management plans are:

- incident identification and notification
- escalation matrix and processes
- remediation measures and processes
- incident reporting and management of knowledge

Prioritization and handling of incidents: e.g.

- criticality of affected resources (e.g. servers, networks, applications etc.)
- potential technical and business impacts of such incidents (e.g. denial of service, data stealing etc.)
- defined SLAs for remediation services, etc.

Technical and tactical measures are:

- IT support
- security
- public affairs
- legal
- human resources
- BDM
- physical security

Operating procedures include:

- required service levels (e.g. availability, quality)
- routine maintenance
- monitoring
- data integrity (e.g. backups, anti-virus)
- consumables use, storage & disposal
- health & safety
- escalation
- information recording and reporting
- obtaining work permissions
- security & confidentiality

SSC/N0911

Monitor applications and solutions deployed for their security for possible breaches and compromises

Basic Cyber Security concepts are: e.g.

- the importance of confidentiality, integrity and availability for information systems
- common types of malicious code- a. virus, b. Trojan; c. logic bomb, d. worm, e. spyware, f. Malwares, g. spoofing, h. phishing, i. Ddos attacks
- types of threats facing the information security of individuals and organisations
- sources of threats to information security in terms of opportunity, ability and motive, etc.

Relevant networking concepts, devices and terminology such as:

- Concepts: OSI (Open Systems Interconnection) Model/topology; Network Protocols, bandwidth management, Vlan, Access control list, Active directory services, port mapping etc.
- Devices: switches, routers, servers, transmission media, Intrusion Protection System (IPS), Load balancers, Firewall etc.
- Terminology: Secure Sockets Layer (SSL), Virtual Private Network (VPN), Two Factor Authentication (2FA), Encryption, Cryptography, smart cards, biometrics, Single sign-on (SSO), Active Directory, Lightweight Directory Access Protocol (LDAP) etc.

Physical and electronic threats are:

- hardware damage
- loss and theft
- denial of service
- data theft or damage
- unauthorized use

Scripting knowledge includes:

- Shell Script
- Java Script

Security solutions are: e.g.

- Firewall
- Intrusion Prevention System (IPS)
- web security gateways
- email security
- content management, etc.

Performance Criteria (PC) w.r.t. the Scope

SSC/N0911

Monitor applications and solutions deployed for their security for possible breaches and compromises

	To be competent, you must be able to: - PC1. verify the scope of application assets and system components to be monitored with stakeholders - PC2. use specified monitoring and data collection methods and tools following organizational procedures and policies - PC3. monitor application consoles using Security Information and Event Management (SIEM) tool to detect security threats and health of the applications - PC4. define and establish operational processes for log management - PC5. identify and capture all the key events and activity logs as per established format using appropriate tools and infrastructure - PC6. ensure that mechanisms such as time stamping and synchronization of servers are utilized for time consistency among all log sources - PC7. maintain a tracker which captures inventory of Cyber security incidents related to applications - PC8. define in co-ordination with seniors and Cyber security incident management team the process for Cyber Security incident/breach management plan and technical and tactical measures deployed to detect or report incidents - PC9. work on the defined process for prioritization and handling of Cyber Security incidents - PC10. characterize and analyze application traffic to identify anomalous activity and potential threats - PC11. identify trends and patterns as per standard guidelines - PC12. coordinate with enterprise-wide computer network defense (CND) staff to validate network alerts - PC13. perform event correlation using information gathered to gain situational awareness and determine the threat potential - PC14. categorize the priority of identified risks by determining their probability of occurrence and potential impact as per organizational processes and policies - PC15. determine actions required to investigate and mitigate identified risks - PC16. raise incidents in Cyber Security Incident logging/reporting tools if something is found suspicious during the analysis - PC17. record and categorize the service request accurately as per organizational processes and policies - PC18. assign the incident to the relevant persons as per the type of risk following organizational procedures - PC19. prioritize the service request according to organizational guidelines - PC20. follow-up with the relevant personnel for taking actions on the incidents raised within agreed timelines
--	--

SSC/N0911

Monitor applications and solutions deployed for their security for possible breaches and compromises

	PC21. obtain help or advice from specialist if the problem is outside his/her area of competence or experience PC22. report the results of the monitoring, incident logging and closure activities using standard documentation following organizational procedures PC23. comply with relevant legislation, standards, policies and procedures PC24. monitor external data sources (e.g., computer network defense [CND] vendor sites, Computer Emergency Response Teams, SANS, Security Focus) and determine which security issues may have an impact on the enterprise PC25. perform telemetry monitoring to identify security platform issues
Knowledge and Understanding (K)	
A. Organizational Context (Knowledge of the company/ organization and its processes)	You need to know and understand: KA1. relevant legislation, standards, policies, and procedures followed in the company KA2. organization's knowledge base and how to access and update this KA3. limits of your role and responsibilities and who to seek guidance from KA4. the organizational systems, procedures and tasks/checklists within the domain and how to use these KA5. how to engage with both internal and external specialists for support in order to resolve incidents and service requests KA6. service request procedures, tools, and techniques KA7. the operating procedures that are applicable to the system(s) being used
B. Technical Knowledge	You need to know and understand: KB1. basic cyber security concepts KB2. relevant networking concepts, devices and terminologies KB3. standard Systems Development Lifecycle (SDLC) practices and process KB4. the enterprise information technology (IT) architecture Information Technology Architecture KB5. what are applications, types of applications and common application security requirements KB6. the basic functionalities of the applications, hardware and/or access rights that are used by the customers KB7. how hardware and software vulnerabilities can be identified and resolved for applications KB8. application / database layer intrusion detection / prevention appliance KB9. measures or indicators of system performance and availability Information KB10. new technological developments in application security KB11. server administration and systems engineering theories, concepts, and methods Systems/Product Life Cycle

SSC/N0911

Monitor applications and solutions deployed for their security for possible breaches and compromises

	KB12. knowledge-base of the known problems KB13. security solutions like Firewall, IDS/IPS, web security gateways, email security, content management, etc. KB14. common Vulnerability and Exposures (CVE) language, which standardizes descriptions of vulnerabilities KB15. how to use Security Incident and Event Management (SIEM) tool for monitoring, reporting, analyzing and raising service requests KB16. operational processes such as report generation, verification, data analysis and correlation, etc. KB17. common types of physical and electronic threats to various types of applications KB18. log management, event and log analysis and packet analysis KB19. typical response times and service times for problems KB20. the importance of documenting, classifying, prioritizing service requests received over voice calls, email, incident management tools and incident reports
Skills (S)	
A. Core Skills/ Generic Skills	Writing Skills
	The user/ individual on the job needs to know and understand how to: SA1. document call logs, reports, task lists, and schedules with co-workers SA2. prepare status and progress reports SA3. write memos and e-mail to customers, co-workers, and vendors to provide them with work updates and to request appropriate information without English language errors regarding grammar or sentence construct and following professional etiquettes
	Reading Skills
	The user/individual on the job needs to know and understand how to: SA4. read about new products and services with reference to the organization and also from external forums such as websites and blogs SA5. keep abreast with the latest knowledge by reading brochures, pamphlets, and product information sheets SA6. read comments, suggestions, and responses to Frequently Asked Questions (FAQs) posted on the helpdesk portal SA7. read policy manual, standard operating procedures and service level agreements relevant to work area SA8. read emails received from own team, across team and external vendors and clients
	Oral Communication (Listening and Speaking skills)
	The user/individual on the job needs to know and understand how to:

SSC/N0911

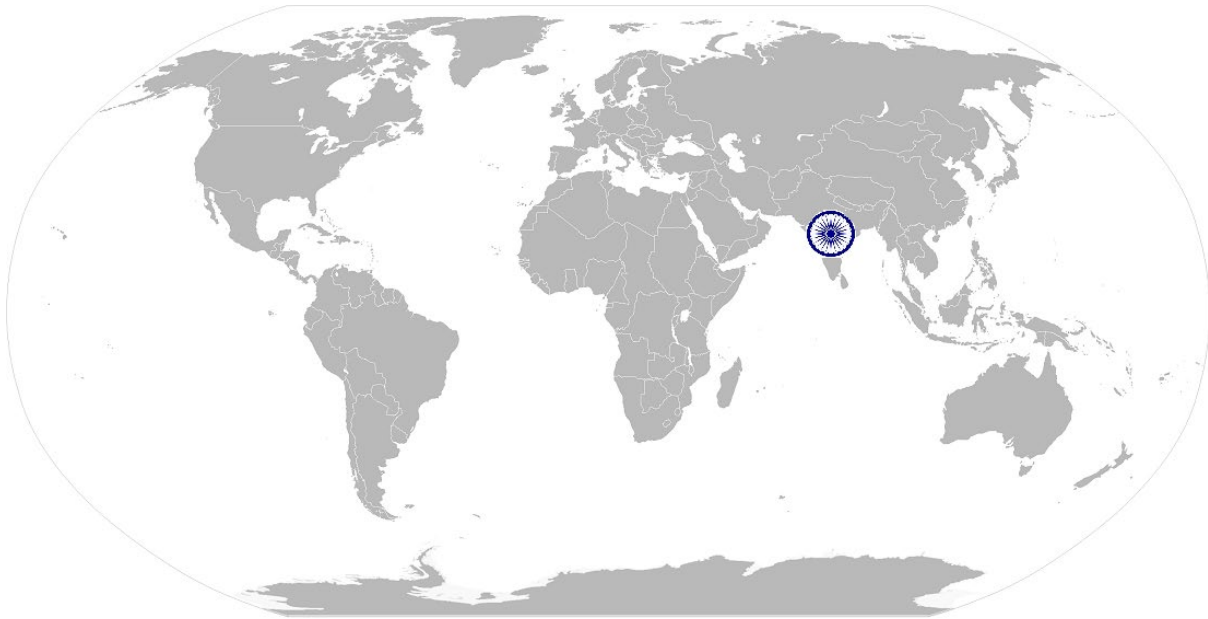
Monitor applications and solutions deployed for their security for possible breaches and compromises

	SA9. discuss task lists, schedules, and work-loads with co-workers SA10. give clear instructions to specialists/vendors/users/clients as required SA11. keep stakeholders informed about progress SA12. avoid using jargon, slang or acronyms when communicating with a customer, unless it is required SA13. receive and make phone calls, including call forward, call hold, and call mute
B. Professional Skills	Decision Making
	The user/individual on the job needs to know and understand how to:
	SB1. follow rule-based decision-making processes
	SB2. make decisions on suitable courses of action
	Plan and Organize
	The user/individual on the job needs to know and understand:
	SB3. plan and organize your work to achieve targets and deadlines
	Customer Centricity
	The user/individual on the job needs to know and understand how to:
	SB4. carry out rule-based transactions in line with customer-specific guidelines,
	SB5. procedures, rules and service level agreements
	SB6. check your own and/or your peers work meets customer requirements
	Problem Solving
	The user/individual on the job needs to know and understand how to:
	SB7. apply problem-solving approaches in different situations
	SB8. seek clarification on problems from others
	Analytical Thinking
	The user/individual on the job needs to know and understand how to:
	SB9. analyze data and activities
	SB10. configure data and disseminate relevant information to others
	SB11. pass on relevant information to others
	Critical Thinking
	The user/individual on the job needs to know and understand how to:
	SB12. provide opinions on work in a detailed and constructive way
	SB13. apply balanced judgments to different situations
	Attention to Detail
	You need to know and understand how to:
	SB14. apply good attention to details
	SB15. check your work is complete and free from errors
	Team Working
	You need to know and understand how to:
	SB16. work effectively in a team environment

SSC/N0911

Monitor applications and solutions deployed for their security for possible breaches and compromises

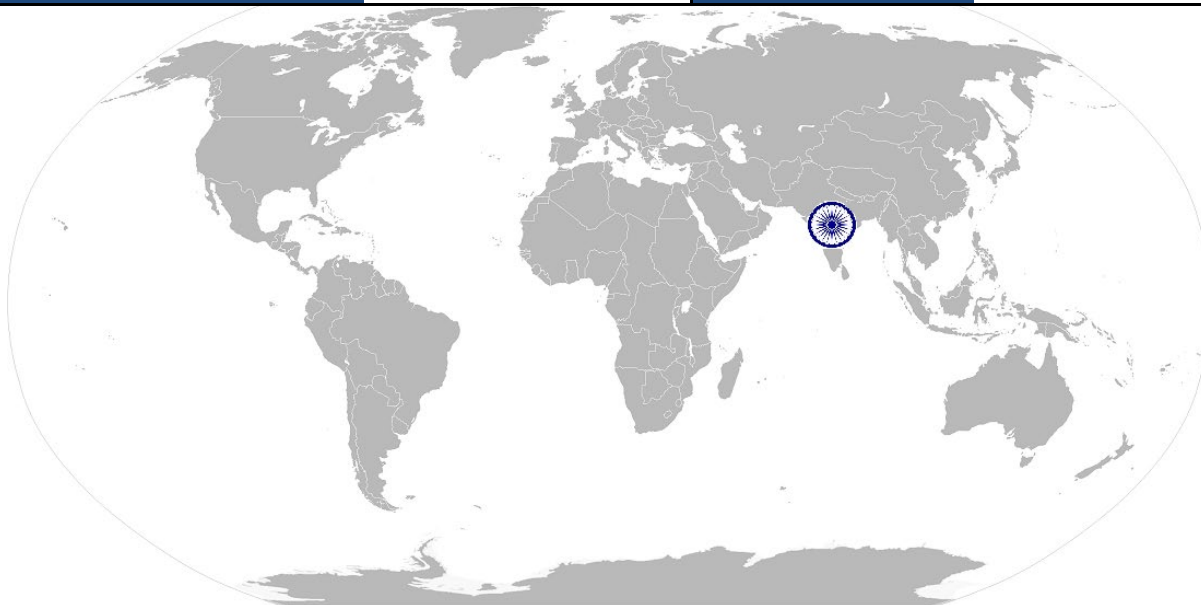
	SB17. contribute to the quality of team working SB18. work independently and collaboratively
C. Technical Skills	You need to know and understand how to: SC1. operate the console of security information and event management tools (SIEM) SC2. work on various operating systems SC3. work with word processors, spreadsheets and presentations SC4. perform basic application penetration testing and ethical hacking SC5. stay abreast of the latest developments in terms of industry standards and information security tools and techniques



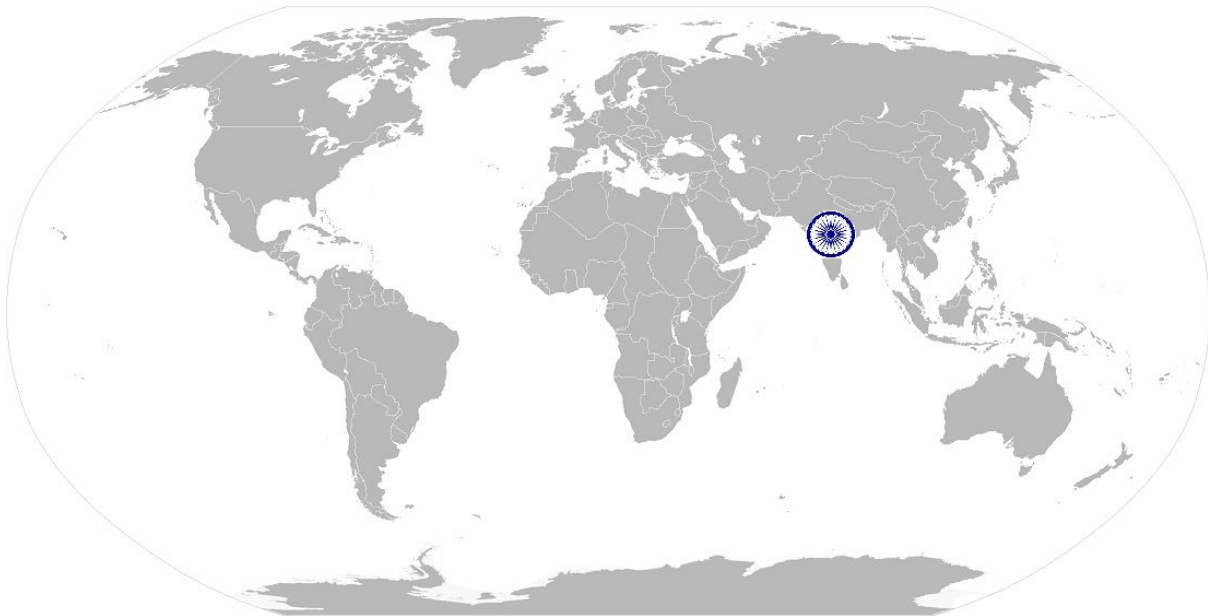
SSC/N0911 Monitor applications and solutions deployed for their security for possible breaches and compromises

NOS Version Control

NOS Code	SSC/N0911		
Credits (NSQF)	TBD	Version number	1.0
Industry	IT-ITes	Drafted on	18/08/2016
Industry Sub-sector	IT Services	Last reviewed on	31/03/2018
Occupation	Information/Cyber Security	Next review date	31/03/2019



National Occupational Standard



Overview

This unit is about planning and organizing your work in order to complete it to the required standards on time

SSC/N9001

Manage your work to meet requirements

Applicable NOS Unit	Unit Code	SSC/N9001
	Unit Title (Task)	Manage your work to meet requirements
	Description	This unit is about planning and organizing your work in order to complete it to the required standards on time.
	Scope	This unit/task covers the following: Work requirements: - activities (what you are required to do) - deliverables (the outputs of your work) - quantity (the volume of work you are expected to complete) - standards (what is acceptable performance, including compliance with Service Level Agreements) - timing (when your work needs to be completed) Appropriate people: - line manager - the person requesting the work - members of the team/department - members from other teams/departments Resources: - equipment - materials - information
Performance Criteria (PC) w.r.t. the Scope		
		To be competent on the job, you must be able to: PC1. establish and agree your work requirements with appropriate people PC2. keep your immediate work area clean and tidy PC3. utilize your time effectively PC4. use resources correctly and efficiently PC5. treat confidential information correctly PC6. work in line with your organization's policies and procedures PC7. work within the limits of your job role PC8. obtain guidance from appropriate people, where necessary

SSC/N9001

Manage your work to meet requirements

	PC9. ensure your work meets the agreed requirements
Knowledge and Understanding (K)	
A. Organizational Context (Knowledge of the company/ organization and its processes)	You need to know and understand: KA1. your organization's policies, procedures and priorities for your area of work and your role and responsibilities in carrying out your work KA2. limits of your responsibilities and when to involve others KA3. your specific work requirements and who these must be agreed with KA4. the importance of having a tidy work area and how to do this KA5. how to prioritize your workload according to urgency and importance and the benefits of this KA6. your organization's policies and procedures for dealing with confidential information and the importance of complying with these KA7. the purpose of keeping others updated with the progress of your work KA8. who to obtain guidance from and the typical circumstances when this may be required KA9. the purpose and value of being flexible and adapting work plans to reflect change
B. Technical Knowledge	You need to know and understand: KB1. the importance of completing work accurately and how to do this KB2. appropriate timescales for completing your work and the implications of not meeting these for you and the organization KB3. resources needed for your work and how to obtain and use these
Skills (S)	
A. Core Skills/ Generic Skills	Writing Skills
	You need to know and understand how to: SA1. complete accurate work with attention to detail
	Reading Skills
	You need to know and understand how to: SA2. read instructions, guidelines, procedures, rules and service level agreements
	Oral Communication (Listening and Speaking skills)
B. Professional Skills	You need to know and understand how to: SA3. ask for clarification and advice from line managers SA4. communicate orally with colleagues
	Decision Making
	You need to know and understand how to: SB1. make a decision on a suitable course of action
	Plan and Organize
	You need to know and understand how to: SB2. plan and organize your work to achieve targets and deadlines

SSC/N9001

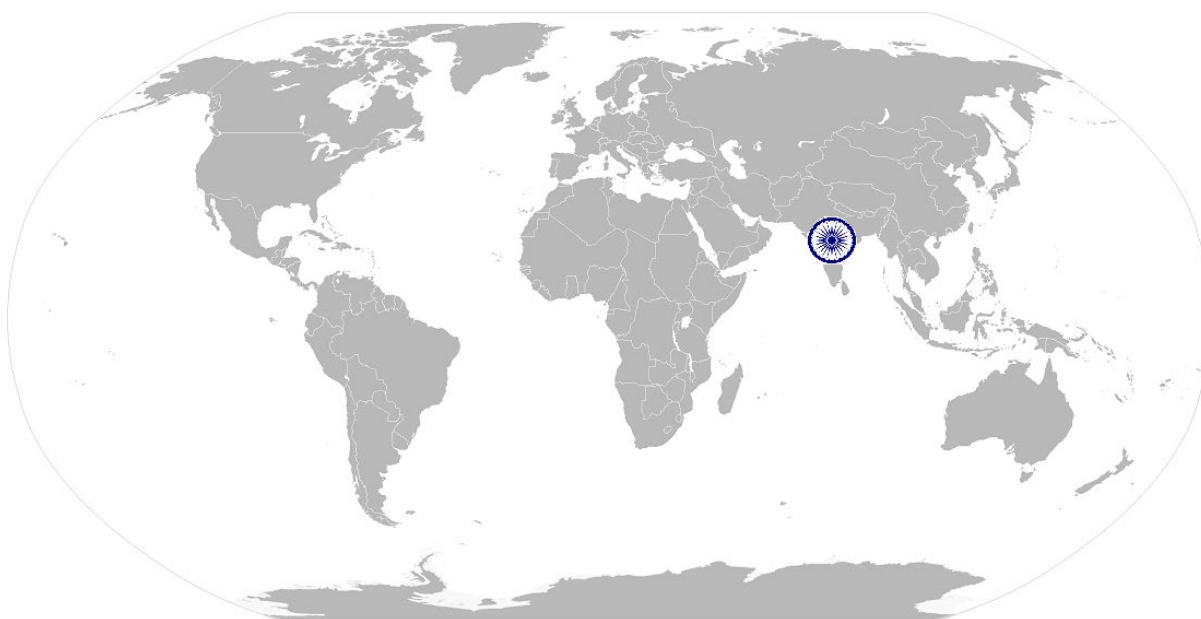
Manage your work to meet requirements

	SB3. agree objectives and work requirements
	Customer Centricity
	You need to know and understand how to:
	SB4. deliver consistent and reliable service to customers
	SB5. check that your own work meets customer requirements
	Problem Solving
	You need to know and understand how to:
	SB6. refer anomalies to the line manager
	SB7. seek clarification on problems from others
	Analytical Thinking
	You need to know and understand how to:
C. Technical Skills	SB8. provide relevant information to others
	SB9. analyze needs, requirements and dependencies in order to meet your work requirements
	Critical Thinking
	You need to know and understand how to:
	SB10. apply judgments to different situations
	Attention to Detail
	You need to know and understand how to:
	SB11. check your work is complete and free from errors
	SB12. get your work checked by peers
	Team Working
	You need to know and understand how to:
	SB13. work effectively in a team environment
	You need to know and understand how to:
	SC1. use information technology effectively, to input and/or extract data accurately
	SC2. identify and refer anomalies in data
	SC3. store and retrieve information
	SC4. keep up to date with changes, procedures and practices in your role

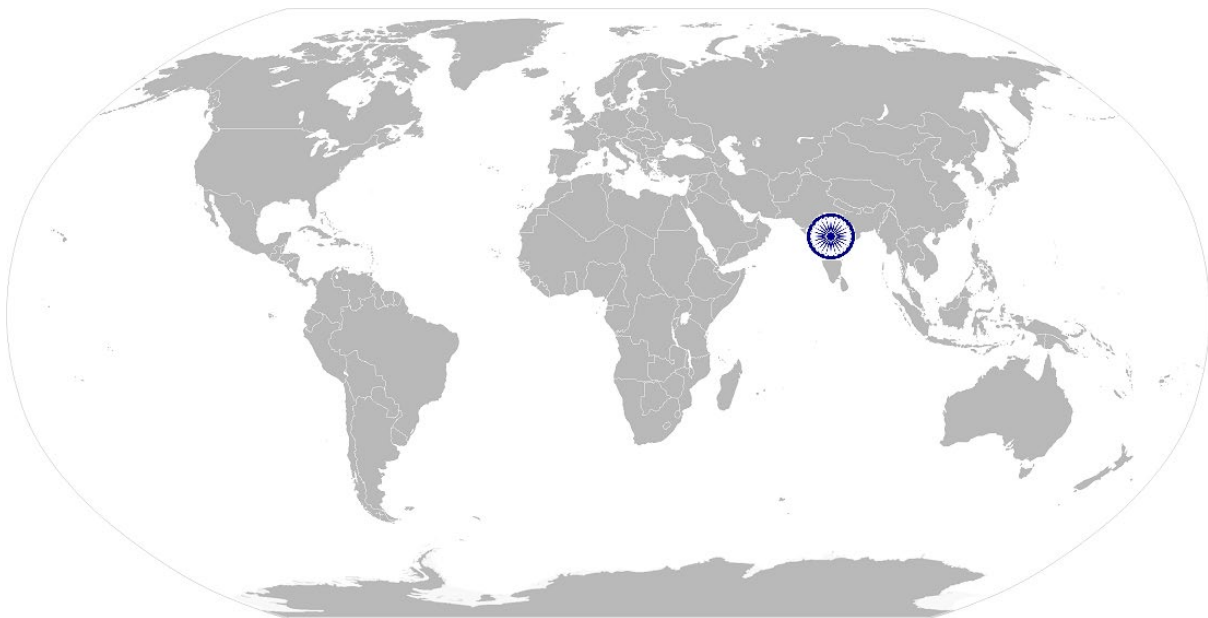
Manage your work to meet requirements

NOS Version Control

NOS Code	SSC/N9001		
Credits (NSQF)	TBD	Version number	1.0
Industry	IT-ITeS	Drafted on	15/03/2016
Industry Sub-sector	IT Services	Last reviewed on	31/03/2018
		Next review date	31/03/2019



National Occupational Standard



Overview

This unit is about working effectively with colleagues, either in your own work group or in other work groups within your organization.

SSC/N9002

Work effectively with colleagues

Applicable NOS Unit

Unit Code	SSC/N9002
Unit Title (Task)	Work effectively with colleagues
Description	This unit is about working effectively with colleagues, either in your own work group or in other work groups within your organization.
Scope	This unit/task covers the following: Colleagues: • line manager • members of your own work group • people in other work groups in your organization Communicate: • face-to-face • by telephone • in writing 
Performance Criteria (PC) w.r.t. the Scope	
	To be competent, you must be able to: PC1. communicate with colleagues clearly, concisely and accurately PC2. work with colleagues to integrate your work effectively with them PC3. pass on essential information to colleagues in line with organizational requirements PC4. work in ways that show respect for colleagues PC5. carry out commitments you have made to colleagues PC6. let colleagues know in good time if you cannot carry out your commitments, explaining the reasons PC7. identify any problems you have working with colleagues and take the initiative to solve these problems PC8. follow the organization's policies and procedures for working with colleagues
Knowledge and Understanding (K)	
A. Organizational Context (Knowledge of the company/ organization and its processes)	You need to know and understand: KA1. your organization's policies and procedures for working with colleagues and your role and responsibilities in relation to this KA2. the importance of effective communication and establishing good working relationships with colleagues

SSC/N9002

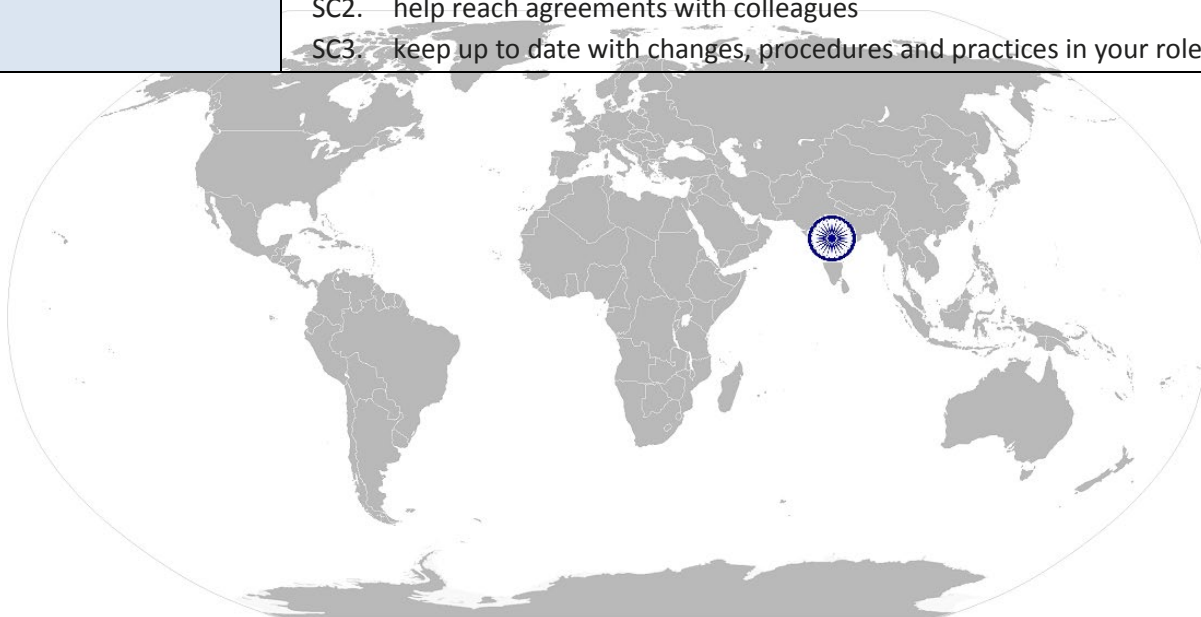
Work effectively with colleagues

	KA3. different methods of communication and the circumstances in which it is appropriate to use these KA4. benefits of developing productive working relationships with colleagues KA5. the importance of creating an environment of trust and mutual respect in an environment where you have no authority over those you are working with KA6. where you do not meet your commitments, the implications this will have on individuals and the organization
B. Technical Knowledge	You need to know and understand: KB1. different types of information that colleagues might need and the importance of providing this information when it is required KB2. the importance of understanding problems from your colleague's perspective and how to provide support, where necessary, to resolve these
Skills (S)	
A. Core Skills/ Generic Skills	Writing Skills
	You need to know and understand how to: SA1. complete accurate, well written work with attention to detail SA2. communicate effectively with colleagues in writing
	Reading Skills
	You need to know and understand how to: SA3. read instructions, guidelines, procedures, rules and service level agreements
	Oral Communication (Listening and Speaking skills)
	You need to know and understand how to: SA4. listen effectively and orally communicate information accurately SA5. ask for clarification and advice from line managers
B. Professional Skills	Decision Making
	You need to know and understand how to: SB1. make a decision on a suitable course of action
	Plan and Organize
	You need to know and understand how to: SB2. plan and organize your work to achieve targets and deadlines
	Customer Centricity
	You need to know and understand how to: SB3. check that your own work meets customer requirements SB4. deliver consistent and reliable service to customers
	Problem Solving
	You need to know and understand how to: SB5. apply problem solving approaches in different situations
	Critical Thinking
	You need to know and understand how to:

SSC/N9002

Work effectively with colleagues

	SB6. apply balanced judgments to different situations
	Attention to Detail
	You need to know and understand how to: SB7. check your work is complete and free from errors SB8. get your work checked by peers
	Team Working
C. Technical Skills	You need to know and understand how to: SB9. work effectively in a team environment SB10. work effectively with colleagues and other teams SB11. treat other cultures with respect
	You need to know and understand how to: SC1. identify and refer anomalies SC2. help reach agreements with colleagues SC3. keep up to date with changes, procedures and practices in your role

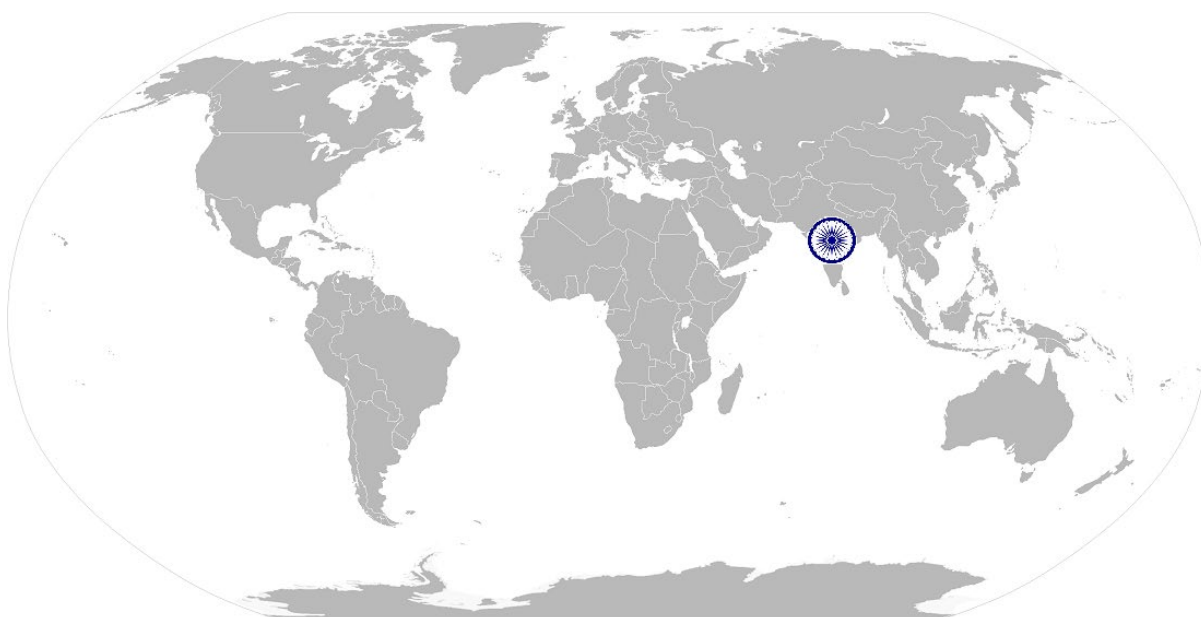


SSC/N9002

Work effectively with colleagues

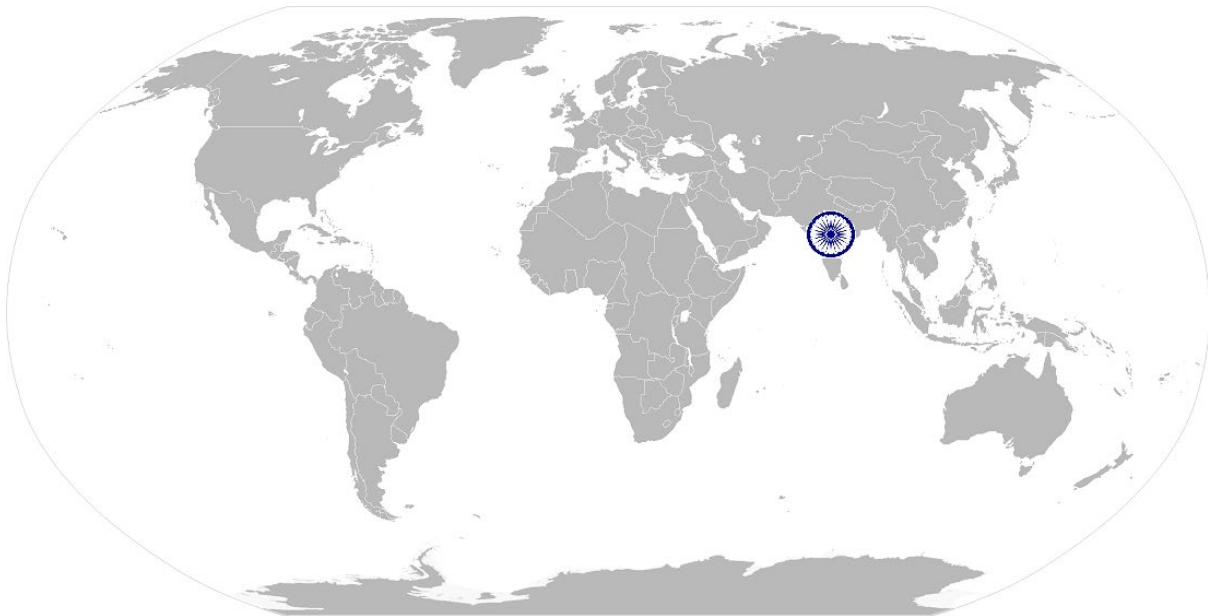
NOS Version Control

NOS Code	SSC/N9002		
Credits(NVEQF/NVQF/NSQF)	TBD	Version number	1.0
Industry	IT-ITes	Drafted on	15/03/2016
Industry Sub-sector	IT Services	Last reviewed on	31/03/2018
		Next review date	31/03/2019



Maintain a healthy, safe and secure working environment

National Occupational Standard



Overview

This unit is about monitoring the working environment and making sure it meets requirements for health, safety and security.

SSC/N9003

Maintain a healthy, safe and secure working environment

Unit Code	SSC/N9003
Unit Title (Task)	Maintain a healthy, safe and secure working environment
Description	This unit is about monitoring your working environment and making sure it meets requirements for health, safety and security.
Scope	This unit/task covers the following: Emergency procedures: • illness • accidents • fires • other reasons to evacuate the premises • breaches of security
Performance Criteria (PC) w.r.t. the Scope	
	To be competent, you must be able to: PC1. comply with your organization's current health, safety and security policies and procedures PC2. report any identified breaches in health, safety, and security policies and procedures to the designated person PC3. identify and correct any hazards that you can deal with safely, competently and within the limits of your authority PC4. report any hazards that you are not competent to deal with to the relevant person in line with organizational procedures and warn other people who may be affected PC5. follow your organization's emergency procedures promptly, calmly, and efficiently PC6. identify and recommend opportunities for improving health, safety, and security to the designated person PC7. complete any health and safety records legibly and accurately
Knowledge and Understanding (K)	
A. Organizational Context (Knowledge of the company/ organization and its processes)	You need to know and understand: KA1. legislative requirements and organization's procedures for health, safety and security and your role and responsibilities in relation to this KA2. what is meant by a hazard, including the different types of health and safety hazards that can be found in the workplace KA3. how and when to report hazards

SSC/N9003

Maintain a healthy, safe and secure working environment

	KA4. limits of your responsibility for dealing with hazards KA5. your organization's emergency procedures for different emergency situations and the importance of following these KA6. the importance of maintaining high standards of health, safety and security KA7. implications that any non-compliance with health, safety and security may have on individuals and the organization
B. Technical Knowledge	You need to know and understand: KB1. different types of breaches in health, safety and security and how and when to report these KB2. evacuation procedures for workers and visitors KB3. how to summon medical assistance and the emergency services, where necessary KB4. how to use the health, safety and accident reporting procedures and the importance of these KB5. government agencies in the areas of safety, health and security and their norms and services
Skills (S)	
A. Core Skills/ Generic Skills	Writing Skills
	You need to know and understand how to: SA1. complete accurate, well written work with attention to detail
	Reading Skills
	You need to know and understand how to: SA2. read instructions, guidelines, procedures, rules and service level agreements
	Oral Communication (Listening and Speaking skills)
	You need to know and understand how to: SA3. listen effectively and orally communicate information accurately
B. Professional Skills	Decision Making
	You need to know and understand how to: SB1. make a decision on a suitable course of action
	Plan and Organize
	You need to know and understand how to: SB2. plan and organize your work to meet health, safety and security requirements
	Customer Centricity
	You need to know and understand how to: SB3. build and maintain positive and effective relationships with colleagues and customers
	Problem Solving
	You need to know and understand how to: SB4. apply problem solving approaches in different situations

SSC/N9003

Maintain a healthy, safe and secure working environment

	Analytical Thinking
	You need to know and understand how to: SB5. analyze data and activities
	Critical Thinking
	You need to know and understand how to: SB6. apply balanced judgments to different situations
	Attention to Detail
	You need to know and understand how to: SB7. check your work is complete and free from errors SB8. get your work checked by peers
	Team Working
	You need to know and understand how to: SB9. work effectively in a team environment
C. Technical Skills	You need to know and understand how to: SC1. identify and refer anomalies SC2. help reach agreements with colleagues SC3. keep up to date with changes, procedures and practices in your role

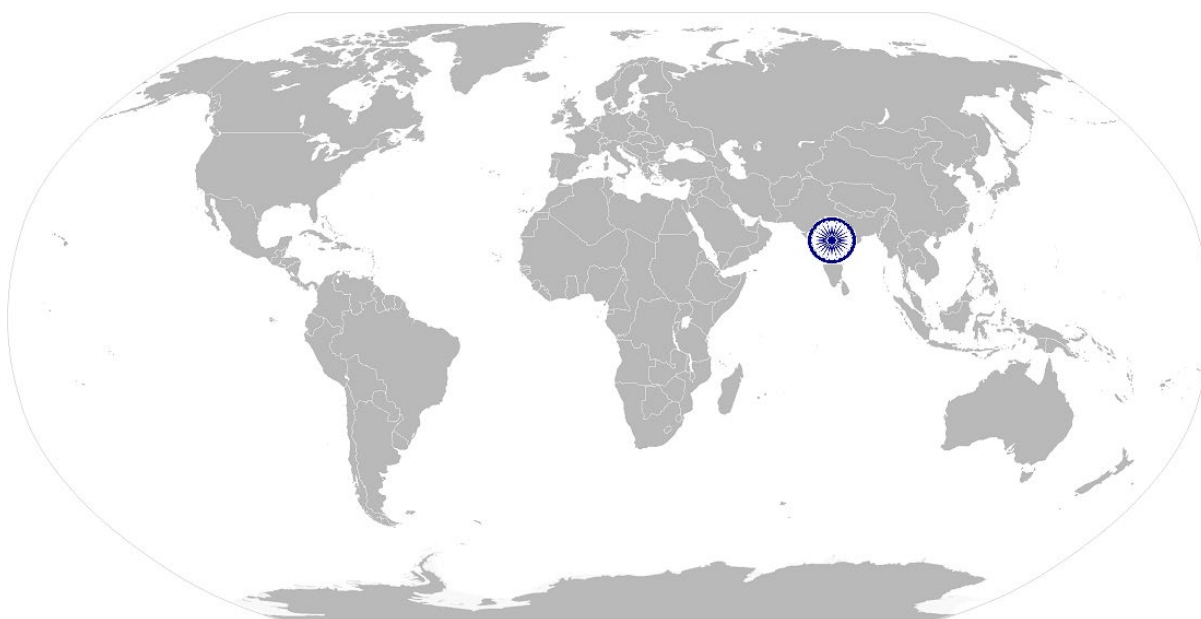


SSC/N9003

Maintain a healthy, safe and secure working environment

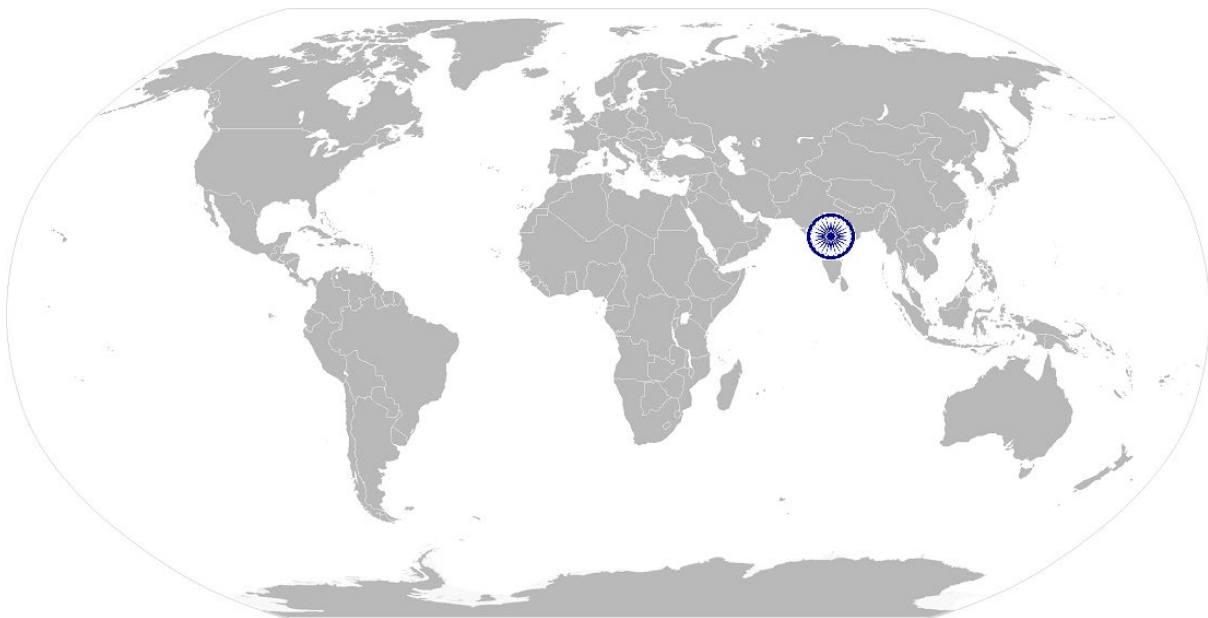
NOS Version Control

NOS Code	SSC/N9003		
Credits (NSQF)	TBD	Version number	1.0
Industry	IT-ITeS	Drafted on	15/03/2016
Industry Sub-sector	IT Services	Last reviewed on	31/03/2018
		Next review date	31/03/2019



Provide data/information in standard formats

National Occupational Standard



Overview

This unit is about providing specified data/information related to your work in templates or other standard formats



SSC/N9004

Provide data/information in standard formats

Unit Code	SSC/N9004
Unit Title (Task)	Provide data/information in standard formats
Description	This unit is about providing specified data/information related to your work in templates or other standard formats.
Scope	This unit/task covers the following: Appropriate people: - line manager - members of your own work group - people in other work groups in your organization - subject matter experts Data/information: - quantitative - qualitative Sources: - within your organization - outside your organization Formats: - paper-based - electronic 
Performance Criteria (PC) w.r.t. the Scope	
	To be competent, you must be able to: PC1. establish and agree with appropriate people the data/information you need to provide, the formats in which you need to provide it, and when you need to provide it PC2. obtain the data/information from reliable sources PC3. check that the data/information is accurate, complete and up-to-date PC4. obtain advice or guidance from appropriate people where there are problems with the data/information PC5. carry out rule-based analysis of the data/information, if required PC6. insert the data/information into the agreed formats PC7. check the accuracy of your work, involving colleagues where required PC8. report any unresolved anomalies in the data/information to appropriate people

SSC/N9004

Provide data/information in standard formats

	PC9. provide complete, accurate and up-to-date data/information to the appropriate people in the required formats on time
Knowledge and Understanding (K)	
A. Organizational Context (Knowledge of the company/ organization and its processes)	You need to know and understand: KA1. your organization's procedures and guidelines for providing data/information in standard formats and your role and responsibilities in relation to this KA2. the knowledge management culture of your organization KA3. your organization's policies and procedures for recording and sharing information and the importance of complying with these KA4. the importance of validating data/information before use and how to do this KA5. procedures for updating data in appropriate formats and with proper validation KA6. the purpose of the CRM database KA7. how to use the CRM database to record and extract information KA8. the importance of having your data/information reviewed by others KA9. the scope of any data/information requirements including the level of detail required KA10. the importance of keeping within the scope of work and adhering to timescales
B. Technical Knowledge	You need to know and understand: KB1. data/information you may need to provide including the sources and how to do this KB2. templates and formats used for data/information including their purpose and how to use these KB3. different techniques used to obtain data/information and how to apply these KB4. these KB5. how to carry out rule-based analysis on the data/information KB6. typical anomalies that may occur in data/information KB7. who to go to in the event of inaccurate data/information and how to report this
Skills (S)	
A. Core Skills/ Generic Skills	Writing Skills
	You need to know and understand how to:
	SA1. complete accurate, well written work with attention to detail
	Reading Skills
	You need to know and understand how to:
	SA2. read instructions, guidelines, procedures, rules and service level agreements
	Oral Communication (Listening and Speaking skills)
	You need to know and understand how to:

SSC/N9004

Provide data/information in standard formats

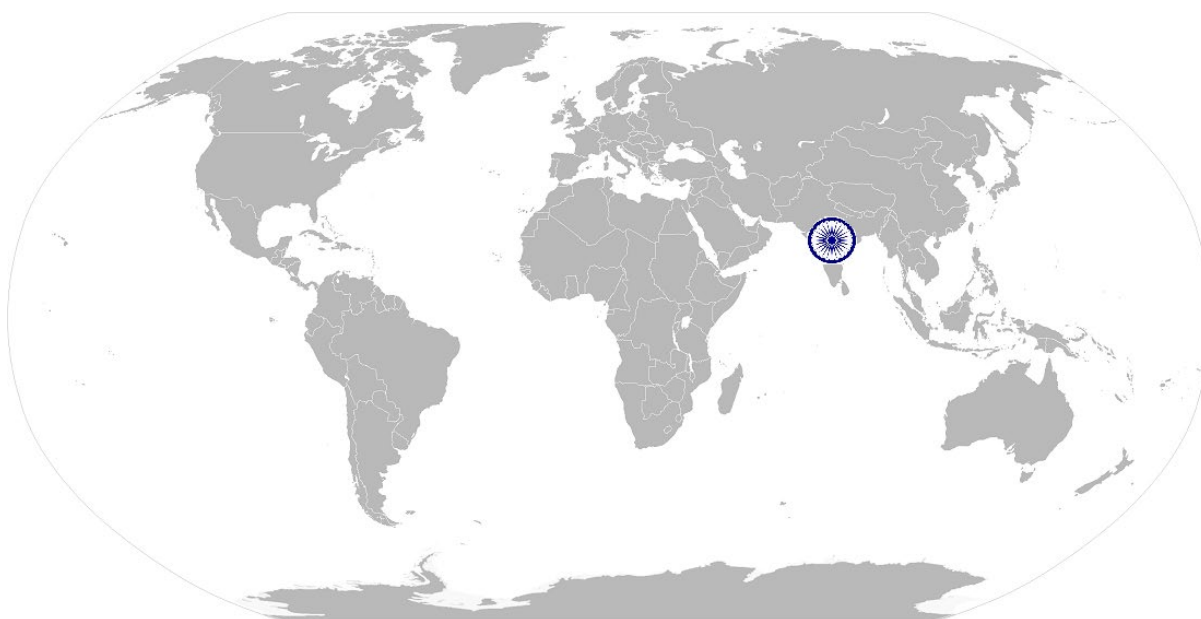
	SA3. listen effectively and orally communicate information accurately
B. Professional Skills	Decision Making
	You need to know and understand how to:
	SB1. follow rule-based decision-making processes
	SB2. make a decision on a suitable course of action
	Plan and Organize
	You need to know and understand how to:
	SB3. plan and organize your work to achieve targets and deadlines
	Customer Centricity
	You need to know and understand how to:
	SB4. check that your own work meets customer requirements
	SB5. meet and exceed customer expectations
	Problem Solving
	You need to know and understand how to:
	SB6. apply problem solving approaches in different situations
C. Technical Skills	Analytical Thinking
	You need to know and understand how to:
	SB7. configure data and disseminate relevant information to others
	Critical Thinking
	You need to know and understand how to:
	SB8. apply balanced judgments to different situations
	Attention to Detail
	You need to know and understand how to:
	SB9. check your work is complete and free from errors
	SB10. get your work checked by peers
	Team Working
	You need to know and understand how to:
	SB11. work effectively in a team environment
C. Technical Skills	You need to know and understand how to:
	SC1. use information technology effectively, to input and/or extract data accurately
	SC2. validate and update data
	SC3. identify and refer anomalies in data
	SC4. store and retrieve information
	SC5. share information using standard formats and templates
	SC6. keep up to date with changes, procedures and practices in your role

SSC/N9004

Provide data/information in standard formats

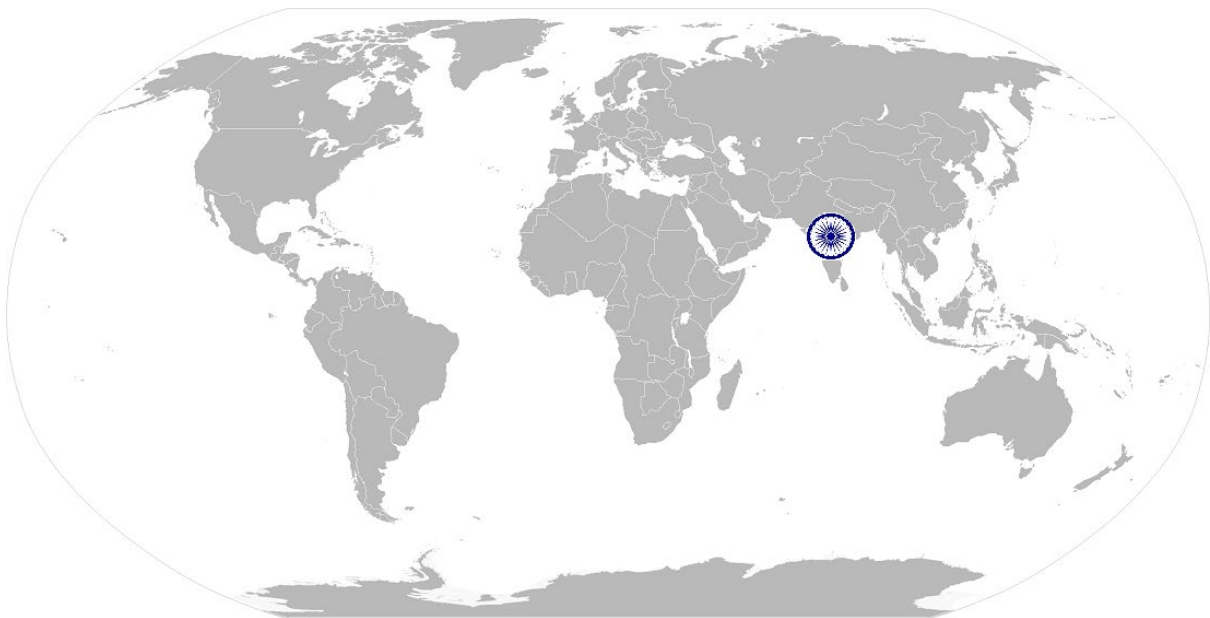
NOS Version Control

NOS Code	SSC/N9004		
Credits (NSQF)	TBD	Version number	1.0
Industry	IT-ITeS	Drafted on	15/03/2016
Industry Sub-sector	IT Services	Last reviewed on	31/03/2018
		Next review date	31/03/2019



Develop your knowledge, skills and competence

National Occupational Standard



Overview

This unit is about taking action to ensure you have the knowledge and skills you need to perform competently in your current job role and to take on new responsibilities, where required.

SSC/N9005

Develop your knowledge, skills and competence

Applicable NOS Unit	Unit Code	SSC/N9005
	Unit Title (Task)	Develop your knowledge, skills and competence
	Description	This unit is about taking action to ensure you have the knowledge and skills you need to perform competently in your current job role and to take on new responsibilities, where required. <i>Competence</i> is defined as: the application of knowledge and skills to perform to the standards required.
	Scope	This unit/task covers the following: Appropriate people may be: - line manager - human resources specialists - learning and development specialists - peers Job role: - current responsibilities as defined in your job description - possible future responsibilities Learning and development activities: - formal education and training programs, leading to certification - non-formal activities (such as private study, learning from colleagues, project work), designed to meet learning and development objectives but without certification Appropriate action may be: - undertaking further learning and development activities - finding further opportunities to apply your knowledge and skills Different Methods are: - training need analysis - skills need analysis - performance appraisals
	Performance Criteria (PC) w.r.t. the Scope	
		To be competent, you must be able to: PC1. obtain advice and guidance from appropriate people to develop your knowledge, skills and competence

SSC/N9005

Develop your knowledge, skills and competence

	PC2. identify accurately the knowledge and skills you need for your job role PC3. identify accurately your current level of knowledge, skills and competence and any learning and development needs PC4. agree with appropriate people a plan of learning and development activities to address your learning needs PC5. undertake learning and development activities in line with your plan PC6. apply your new knowledge and skills in the workplace, under supervision PC7. obtain feedback from appropriate people on your knowledge and skills and how effectively you apply them PC8. review your knowledge, skills and competence regularly and take appropriate action
Knowledge and Understanding (K)	
A. Organizational Context (Knowledge of the company/ organization and its processes)	You need to know and understand: KA1. your organization's procedures and guidelines for developing your knowledge, skills and competence and your role and responsibilities in relation to this KA2. the importance of developing your knowledge, skills and competence to you and your organization KA3. different methods used by your organization to review skills and knowledge including: KA4. how to review your knowledge and skills against your job role using different methods and analysis KA5. different types of learning and development activities available for your job role and how to access these KA6. how to produce a plan to address your learning and development needs, who to agree it with and the importance of undertaking the planned activities KA7. different types of support available to help you plan and undertake learning and development activities and how to access these KA8. why it is important to maintain records of your learning and development KA9. methods of obtaining and accepting feedback from appropriate people on your knowledge skills and competence KA10. how to use feedback to develop in your job role
B. Technical Knowledge	You need to know and understand: KB1. the knowledge and skills required in your job role KB2. your current learning and development needs in relation to your job role KB3. different types of learning styles and methods including those that help you learn best KB4. the importance of taking responsibility for your own learning and development



SSC/N9005

Develop your knowledge, skills and competence

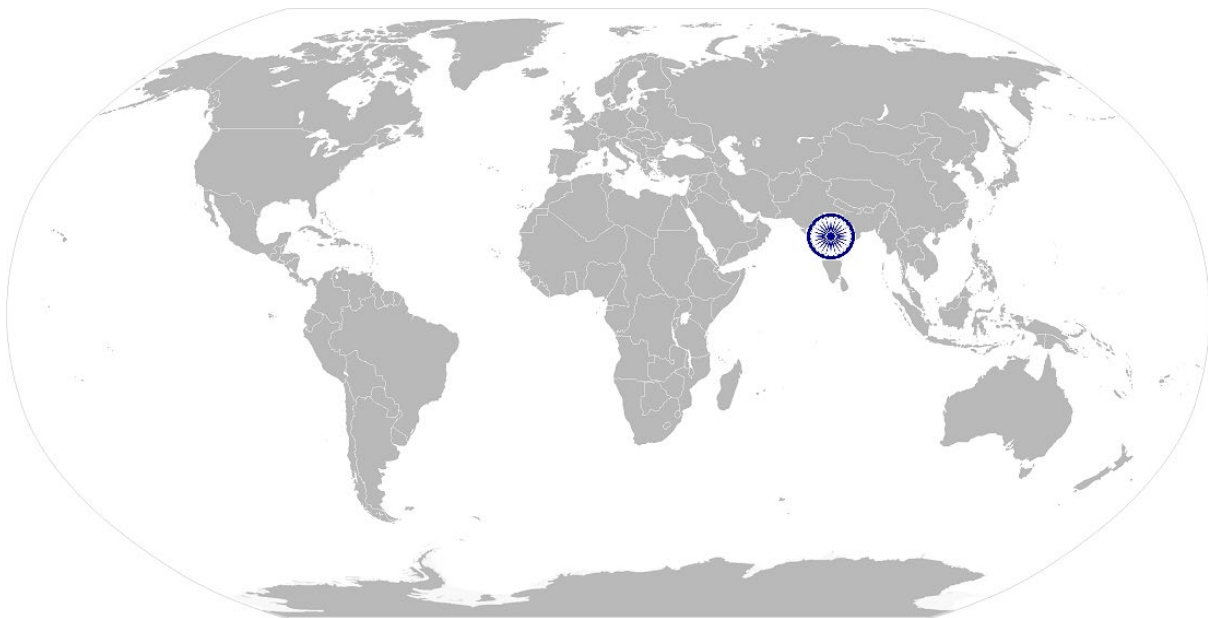
	KB5. to the importance of learning and practicing new concepts, theory and how to apply these in the work environment or on samples. KB6. how to explore sample problems and apply solutions
Skills (S)	
A. Core Skills/ Generic Skills	Writing Skills
	You need to know and understand how to:
	SA1. communicate with colleagues in writing
	Reading Skills
	You need to know and understand how to:
B. Professional Skills	SA2. read instructions, guidelines and procedures
	Oral Communication (Listening and Speaking skills)
	You need to know and understand how to:
	SA3. ask for clarification and advice from line managers
	Decision Making
C. Technical Skills	You need to know and understand how to:
	SB1. make a decision on a suitable course of action
	Plan and Organize
	You need to know and understand how to:
	SB2. plan and organize your work to achieve targets and deadlines
	Customer Centricity
	You need to know and understand how to:
	SB3. check that your own work meets customer requirements
	Problem Solving
	You need to know and understand how to:
	SB4. refer anomalies to the line manager
	Analytical Thinking
	You need to know and understand how to:
	SB5. analyze data and activities
	Critical Thinking
	You need to know and understand how to:
	SB6. apply balanced judgments to different situations
	Attention to Detail
	You need to know and understand how to:
	SB7. check your work is complete and free from errors
	SB8. get your work checked by peers
	Team Working
	You need to know and understand how to:
	SB9. work effectively in a team environment
	C. Technical Skills
	You need to know and understand how to:



SSC/N9005

Develop your knowledge, skills and competence

	SC1. use information technology effectively SC2. agree objectives and work requirements SC3. keep up to date with changes, procedures and practices in your role
--	---

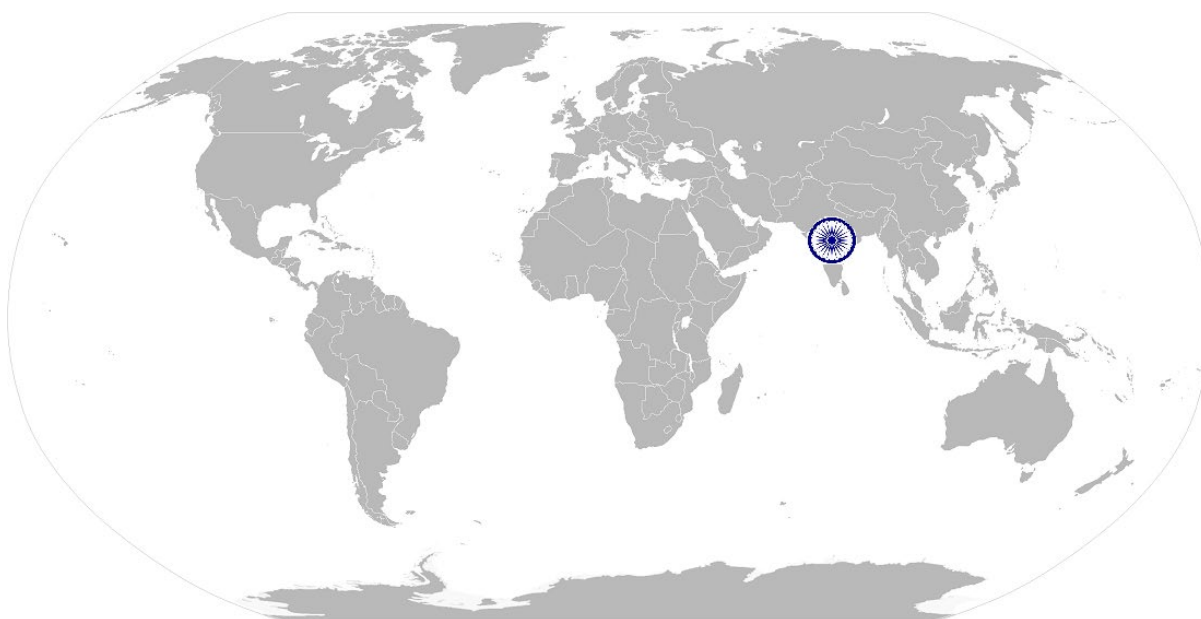


SSC/N9005

Develop your knowledge, skills and competence

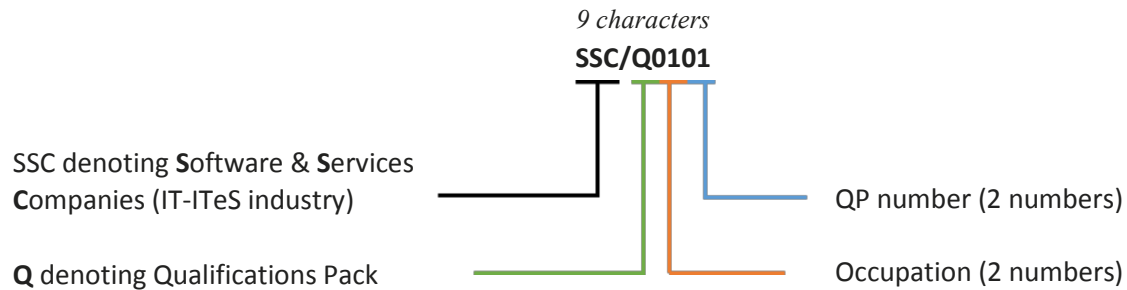
NOS Version Control

NOS Code	SSC/N9005		
Credits (NSQF)	TBD	Version number	1.0
Industry	IT-ITeS	Drafted on	15/03/2016
Industry Sub-sector	IT Services	Last reviewed on	31/03/2018
		Next review date	31/03/2019

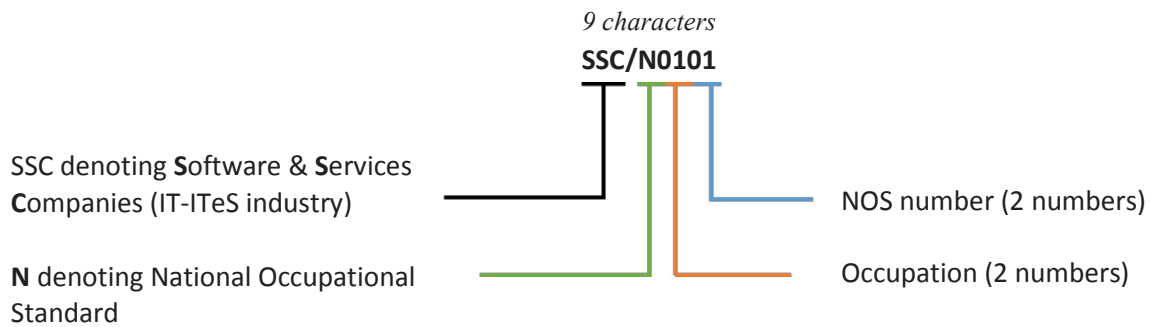


Nomenclature for QP and NOS Units

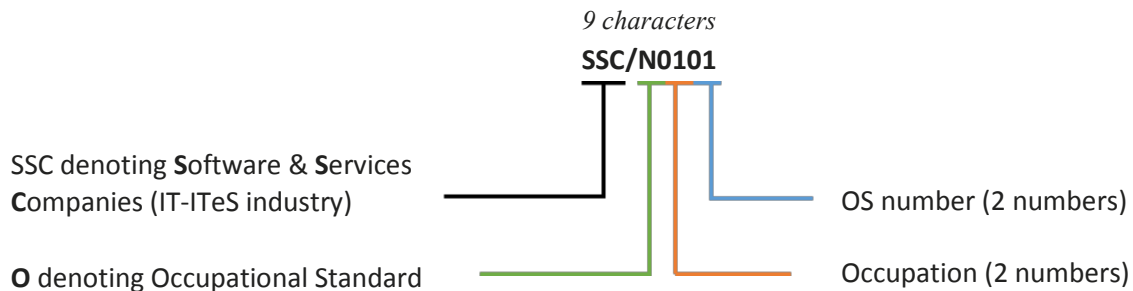
Qualifications Pack



National Occupational Standard



Occupational Standard



It is important to note that an OS unit can be denoted with either an 'O' or an 'N'.

- If an OS unit denotes 'O', it is an OS unit that is an international standard. An example of OS unit denoting 'O' is SSC/O0101.
- If an OS unit denotes 'N', it is an OS unit that is a national standard and is applicable only for the Indian IT-ITeS industry. An example of OS unit denoting 'N' is SSC/N0101

Nomenclature for QP and NOS Units

The following acronyms/codes have been used in the nomenclature above:

Sub-Sector	Range of Occupation numbers
IT Service (ITS)	01-20
Business Process Management (BPM)	21-40
Engg. and R&D (ERD)	41-60
Software Products (SPD)	61-80

Sequence	Description	Example
Three letters	Industry name (Software & Service Companies)	SSC
Slash	/	/
Next letter	Whether QP or NOS	N
Next two numbers	Occupation Code	01
Next two numbers	OS number	01

Criteria for Assessment of Trainees

<u>Job Role</u>	Analyst Application Security
<u>Qualification Pack</u>	SSC/Q0903
<u>Sector Skill Council</u>	IT-ITeS

Guidelines for Assessment:

1. Criteria for assessment for each Qualification Pack (QP) will be created by the Sector Skill Council (SSC). Each performance criteria (PC) will be assigned Theory and Skill/Practical marks proportional to its importance in NOS.
2. The assessment will be conducted online through assessment providers authorised by SSC.
3. Format of questions will include a variety of styles suitable to the PC being tested such as multiple choice questions, fill in the blanks, situational judgment test, simulation and programming test.
4. To pass a QP, a trainee should pass each individual NOS. Standard passing criteria for each NOS is 70%.
5. For latest details on the assessment criteria, please visit www.sscnasscom.com.
6. In case of successfully passing only certain number of NOS's, the trainee is eligible to take subsequent assessment on the balance NOS's to pass the Qualification Pack.

Assessment Outcomes	Assessment Criteria for Outcomes	Mark Allocation			
		Total Marks	Out of	Theory	Skills Practical
1. SSC/N0909 (Identify exposures and weaknesses in applications and their deployments)	PC1. gather preliminary information about the application through manual documentation review	100	5	2	3
	PC2. evaluate the criticality of information by taking into consideration various factors		5	1	4
	PC3. identify the application type/category by considering various factors		3	1	2
	PC4. gather web-based information through the use of automated tools and techniques		5	2	3
	PC5. establish the application functionality, connectivity, interdependency and working		5	2	3
	PC6. review application design and architecture to check that appropriate security requirements are enforced		3	1	2

Criteria for Assessment of Trainees

PC7. check the source code of an application manually and identify security issues	4	1	3
PC8. explore potential threats by considering threats from various sources	5	1	4
PC9. evaluate the vulnerabilities discovered for their relevance, root causes, risk criticality, and corresponding mitigation methods	4	1	3
PC10. collate application security controls from various internal and external sources	4	1	3
PC11. collate information about the application with respect to industry trends through various sources	4	1	3
PC12. gather information related to application patching and its interdependencies with IT infrastructure requirements	4	1	3
PC13. assess application vulnerability using security assessment tools	4	1	3
PC14. isolate root causes of vulnerabilities and identify fixes, by including contextual information like architectural composition, exploitation methods, and probabilities of exposure	4	1	3
PC15. validate data to identify failed false positives and individual vulnerabilities	4	2	2
PC16. categorize vulnerabilities and identify extent of vulnerability including level of weakness and sensitivity of the information	4	1	3
PC17. develop an application tracker capturing relevant information	3	1	2
PC18. plan for application penetration testing covering various parameters	4	1	3
PC19. test applications using various testing methods	5	2	3

Criteria for Assessment of Trainees

	PC20. Conduct penetration testing using automatic scanning technologies, “black box testing, as well as manual tests that use human intelligence to guide the steps		5	2	3
	PC21. capture the requirements for securing applications stipulated by clients & external stakeholders in designated format during the application life cycle		4	1	3
	PC22. document information and activities at every step to provide an audit trail		4	2	2
	PC23. secure storage of data collected during the assessment, including vulnerabilities, analysis results, and mitigation recommendations		4	1	3
	PC24. automate correlation of static, dynamic and interactive application security testing results		4	1	3
		Total	100	31	69
2. SSC/N0910 (Harden application and deployment configurations for minimizing exposure and vulnerabilities)	PC1. identify all web servers and web applications on the network and secure their administrative consoles	100	4	1	3
	PC2. review the list of all applications and ensure valid credentials are required to connect		3	1	2
	PC3. review list of systems and applications to identify and uninstall unauthorized instances and extraneous functionality to reduce the chance of exploitation		3	1	2
	PC4. apply access controls to applications and databases as required as per policy		5	1	4
	PC5. ensure all web servers, web applications and databases are patched as per latest guidelines		4	1	3

Criteria for Assessment of Trainees

PC6. ensure all follow security technical implementation guides (STIGs) to ensure compliance with best practices	3	1	2
PC7. review logs for web attacks and identify signs of compromise	4	1	3
PC8. implement application and database defenses such as firewalls	6	2	4
PC9. ensure that all applications connect with least privilege	4	1	3
PC10. limit and monitor file creation in all web accessible directories	4	1	3
PC11. configure application securely across the environments for minimum exposure and weaknesses	6	2	4
PC12. secure applications using tools and solutions such as application testing, code review, web application firewall, etc	6	2	4
PC13. check frontend and backend platforms for reported vulnerabilities and available patches or updates	4	1	3
PC14. work on the established guidelines (or establish new ones with the support of a senior) for security configuration and hardening for each category of applications	4	1	3
PC15. establish mechanism and measures to ensure that security updates and patches are effectively applied on all the application assets	4	1	3
PC16. define security baseline for malware protection — at servers, endpoints and applications and their signatures updates including patch/security updates	6	2	4
PC17. make the business users aware about application vulnerability and patch requirements	4	1	3
PC18. define strategy for management of patches and updates considering various relevant factors	6	2	4

Criteria for Assessment of Trainees

	PC19. identify a patch management life cycle process considering various parameters		4	1	3
	PC20. integrate patch management with the operational cycle of IT infrastructure management		5	1	4
	PC21. ensure that IT infrastructure processes are reengineered as per the patch management requirements		3	1	2
	PC22. research best practices in hardening applications		4	2	2
	PC23. document results of the outcome of the tools and solutions used		4	2	2
		Total	100	30	70
3. SSC/N0911 (Monitor applications and solutions deployed their security for possible breaches and compromises)	PC1. verify the scope of application assets and system components to be monitored with authorized persons	100	3	1	2
	PC2. use specified monitoring and data collection methods and tools following organisational procedures and policies		6	2	4
	PC3. monitor application consoles using Security Information and Event Management (SIEM) tool to detect security threats and health of the applications		6	2	4
	PC4. define and establish operational processes for log management		4	2	2
	PC5. identify and capture all the key events and activity logs as per established format using appropriate tools and infrastructure		6	2	4
	PC6. ensure that mechanisms such as time stamping and synchronization of servers are utilized for time consistency among all log sources		3	1	2
	PC7. maintain a tracker which captures inventory of incidents related to applications		3	1	2

Criteria for Assessment of Trainees

PC8. define in co-ordination with seniors and incident management team the process for incident/breach management plan and technical and tactical measures deployed to detect or report incidents	3	1	2
PC9. work on the defined process for prioritization and handling of incidents	3	1	2
PC10. characterize and analyze application traffic to identify anomalous activity and potential threats	6	2	4
PC11. identify trends and patterns as per standard guidelines	5	2	3
PC12. coordinate with enterprise-wide computer network defense (CND) staff to validate network alerts	3	1	2
PC13. perform event correlation using information gathered to gain situational awareness and determine the threat potential	4	1	3
PC14. categorize the priority of identified risks by determining their probability of occurrence and potential impact as per organizational processes and policies	5	1	4
PC15. determine actions required to investigate and mitigate identified risks	4	1	3
PC16. raise incidents in ticketing tools if something is found suspicious during the analysis	4	1	3
PC17. record and categorize the service request accurately as per organizational processes and policies	5	1	4
PC18. assign the ticket to the relevant persons as per the type of risk following organizational procedures	4	1	3
PC19. prioritize the service request according to organizational guidelines	4	1	3

Criteria for Assessment of Trainees

	PC20. follow-up with the relevant personnel for taking actions on the tickets raised within agreed timelines		3	0	3
	PC21. obtain help or advice from specialist if the problem is outside his/her area of competence or experience		3	0	3
	PC22. report the results of the monitoring, ticket raising and ticket closure activities using standard documentation following organizational procedures		3	1	2
	PC23. comply with relevant legislation, standards, policies and procedures		2	1	1
	PC24. monitor external data sources (e.g., computer network defense [CND] vendor sites, Computer Emergency Response Teams, SANS, Security Focus) and determine which security issues may have an impact on the enterprise		4	2	2
	PC25. perform telemetry monitoring to identify security platform issues		4	1	3
		Total	100	30	70
4. SSC/N9001 (Manage your work to meet requirements)	PC1. establish and agree your work requirements with appropriate people	100	7	0	7
	PC2. keep your immediate work area clean and tidy		12	6	6
	PC3. utilize your time effectively		12	6	6
	PC4. use resources correctly and efficiently		19	6	13
	PC5. treat confidential information correctly		7	1	6
	PC6. work in line with your organization's policies and procedures		12	0	12
	PC7. work within the limits of your job role		6	0	6
	PC8. obtain guidance from appropriate people, where necessary		6	0	6

Criteria for Assessment of Trainees

	PC9. ensure your work meets the agreed requirements		19	6	13
		Total	100	25	75
5. SSC/N9002 (Work effectively with colleagues)	PC1. communicate with colleagues clearly, concisely and accurately	100	20	0	20
	PC2. work with colleagues to integrate your work effectively with theirs		10	0	10
	PC3. pass on essential information to colleagues in line with organizational requirements		10	10	0
	PC4. work in ways that show respect for colleagues		20	0	20
	PC5. carry out commitments you have made to colleagues		10	0	10
	PC6. let colleagues know in good time if you cannot carry out your commitments, explaining the reasons		10	10	0
	PC7. identify any problems you have working with colleagues and take the initiative to solve these problems		10	0	10
	PC8. follow the organization's policies and procedures for working with colleagues		10	0	10
		Total	100	20	80
6. SSC/N9003 (Maintain a healthy, safe and secure working environment)	PC1. comply with your organization's current health, safety and security policies and procedures	100	20	10	10
	PC2. report any identified breaches in health, safety, and security policies and procedures to the designated person		10	0	10
	PC3. identify and correct any hazards that you can deal with safely, competently and within the limits of your authority		20	10	10

Criteria for Assessment of Trainees

	PC4. report any hazards that you are not competent to deal with to the relevant person in line with organizational procedures and warn other people who may be affected		10	0	10
	PC5. follow your organization's emergency procedures promptly, calmly, and efficiently		20	10	10
	PC6. identify and recommend opportunities for improving health, safety, and security to the designated person		10	0	10
	PC7. complete any health and safety records legibly and accurately		10	0	10
		Total	100	30	70
7. SSC/N9004 (Provide data/information in standard formats)	PC1. establish and agree with appropriate people the data/information you need to provide, the formats in which you need to provide it, and when you need to provide it	100	13	13	0
	PC2. obtain the data/information from reliable sources		13	0	13
	PC3. check that the data/information is accurate, complete and up-to-date		12	6	6
	PC4. obtain advice or guidance from appropriate people where there are problems with the data/information		6	0	6
	PC5. carry out rule-based analysis of the data/information, if required		25	0	25
	PC6. insert the data/information into the agreed formats		13	0	13
	PC7. check the accuracy of your work, involving colleagues where required		6	0	6
	PC8. report any unresolved anomalies in the data/information to appropriate people		6	6	0
	PC9. provide complete, accurate and up-to-date data/information to the		6	0	6

Criteria for Assessment of Trainees

	appropriate people in the required formats on time				
		Total	100	25	75
8. SSC/N9005 (Develop your knowledge, skills and competence)	PC1. obtain advice and guidance from appropriate people to develop your knowledge, skills and competence	100	10	0	10
	PC2. identify accurately the knowledge and skills you need for your job role		10	0	10
	PC3. identify accurately your current level of knowledge, skills and competence and any learning and development needs		20	10	10
	PC4. agree with appropriate people a plan of learning and development activities to address your learning needs		10	0	10
	PC5. undertake learning and development activities in line with your plan		20	10	10
	PC6. apply your new knowledge and skills in the workplace, under supervision		10	0	10
	PC7. obtain feedback from appropriate people on your knowledge and skills and how effectively you apply them		10	0	10
	PC8. review your knowledge, skills and competence regularly and take appropriate action		10	0	10
		Total	100	20	80